Chapter 4

Network and Security Management

中央資管
陳奕明

Panko and Panko
Business Data Networks and Security, 10th Edition, Global Edition
Copyright © 2015 Pearson Education, Ltd.

Failure in the Target Breach

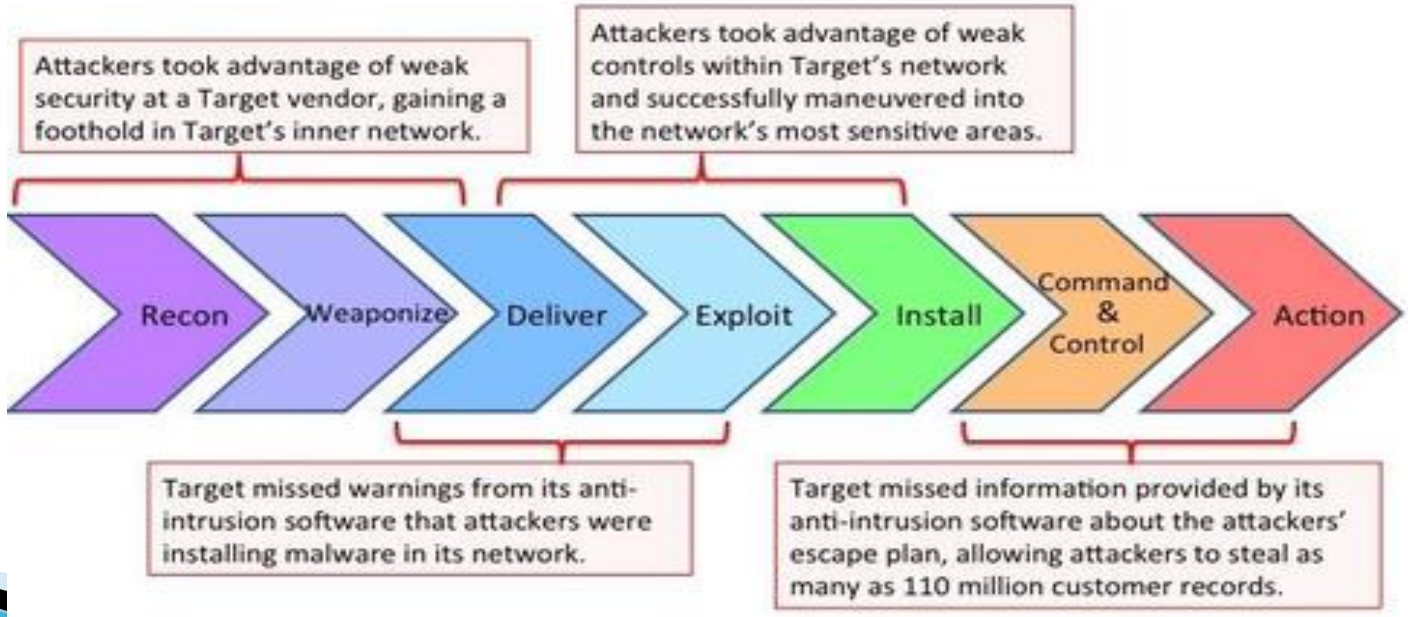
- Cost Matters
- Network Quality of Service QoS
- Network Design
- Security Planning Principles
- Centralized Management

Failures in the Target Breach

- **Security is a Process, not a Product**
- Fazio Engineering Services
  - **Contractor with weak security** →Fell for **spear phishing** attack, giving access to the vendor server
  - Fazio used a **free** antivirus program **not meant for corporations** →Did not warn for individual messages
- Was Able to Move to **Sensitive Servers**
  - **Should not** have been able to
- **Ignored** Explicit **Warnings**
  - Priority warning from the FireEye IDS service
  - November 30, December 1, December 3
  - Exfiltration began on December 2

Kill Chain Analysis

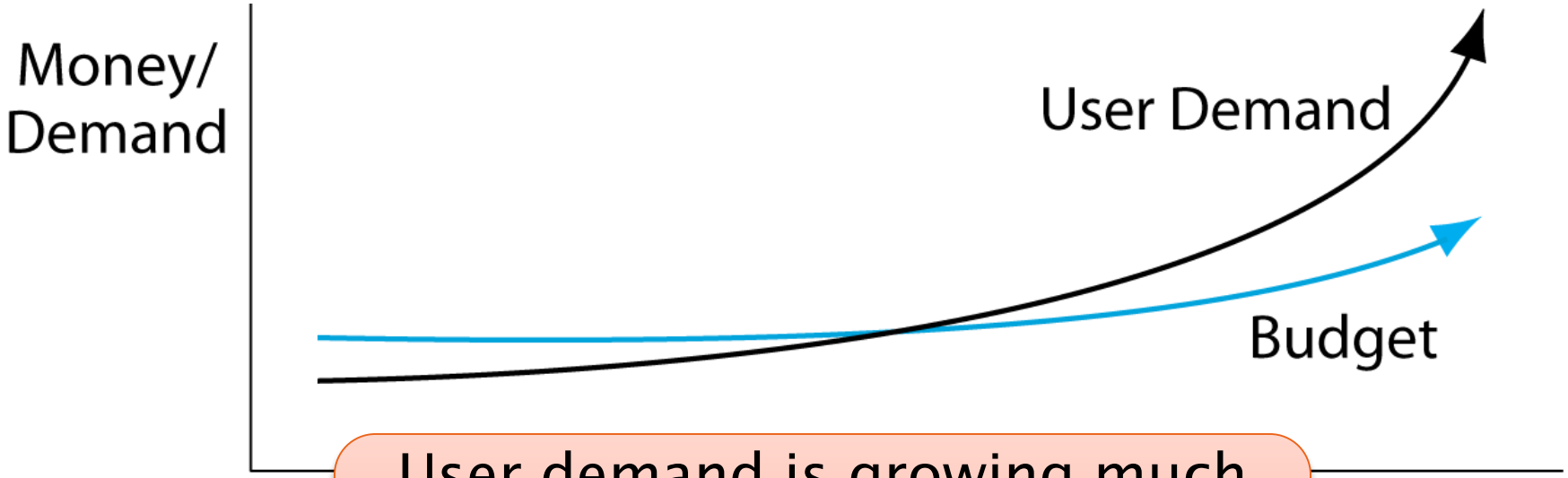
- For a weapon to succeed, a number of steps must go correctly ← called the **kill chain**
- Companies must look for evidence of kill chain patters and end the chain before the end



- Failure in the Target Breach
- **Cost Matters**
- Network Quality of Service QoS
- Network Design
- Security Planning Principles
- Centralized Management

Copyright © 2015 Pearson Education, Ltd.

4.1 Network Demand and Budgets



User demand is growing much faster than network budgets.

Cost efficiency is always critical.

- Failure in the Target Breach
- Cost Matters
- **Network Quality of Service QoS**
- Network Design
- Security Planning Principles
- Centralized Management

Copyright © 2015 Pearson Education, Ltd.

4.2 Quality-of-Service (QoS) Metrics



Speed:
Transmission Speed in Bits per Second (bps)



Errors:
Percentage of Incorrect Bits or Packets



Availability:
Percentage of Time Network is Available to Users



Latency:
Time Delay in Packet Delivery, Measured in Milliseconds (ms)

Copyright © 2015 Pearson Education, Ltd.

Transmission Speed

- Rated Speed
  - The speed a system should achieve,
  - According to vendor claims or the standard that defines the technology.
- Throughput
  - The speed a system *actually* provides to users
  - (Almost always lower)

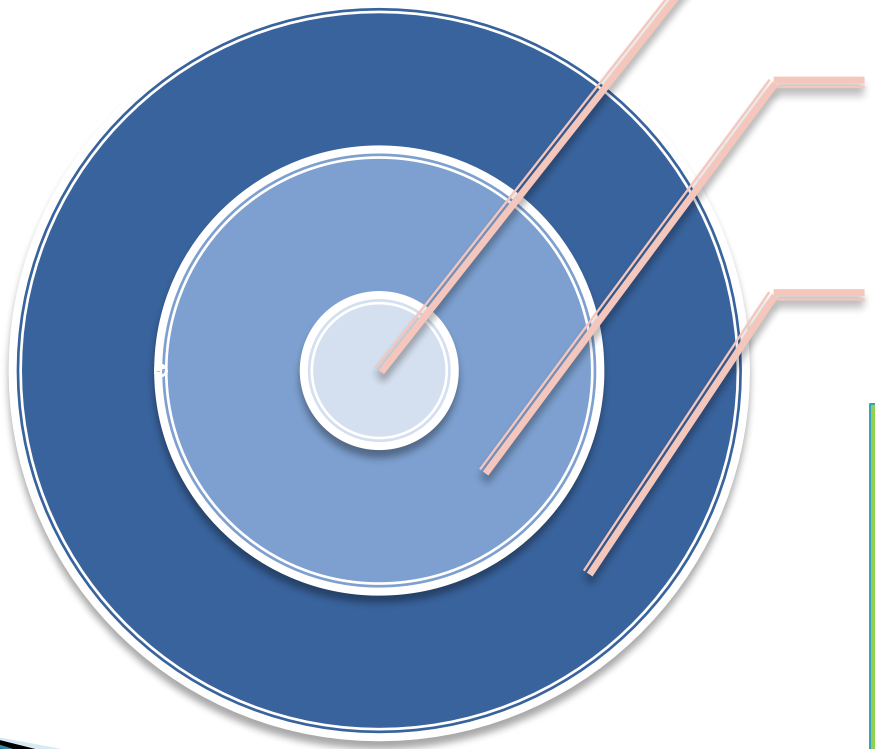
Aggregate Throughput

The aggregate throughput is the total throughput available to all users.

Individual Throughput

An individual's share of the aggregate throughput

Transmission Speed



Individual throughput

Aggregate throughput

Rated speed

Aggregate Throughput

The aggregate throughput is the total throughput available to all users.

Individual Throughput

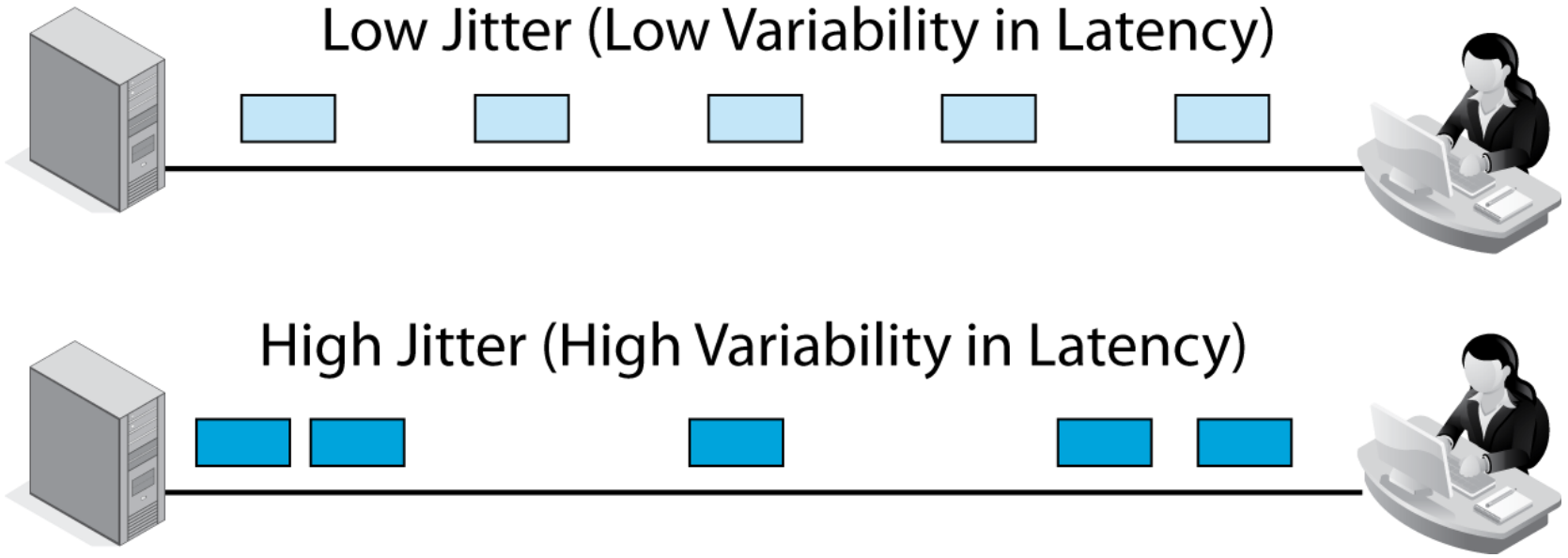
An individual's share of the aggregate throughput

Speed Knowledge Check

1. You are in a Wi-Fi hot spot with 20 other people. The access point router is rated as following the 802.11ac standard with options providing 300 Mbps.
2. Throughput is about 50%. At a certain moment, you and four others are sending and receiving.

→What individual throughput are you likely to receive?

4.4 Jitter



Jitter is variability in latency
Makes voice and video seem “jittery”
Engineering networks to reduce jitter can be expensive

Copyright © 2015 Pearson Education, Ltd.

4.5 Service Level Agreements (SLAs)1/3

- Guarantees for performance
- Increasingly demanded by users
- Penalties if the network does not meet its QoS metric guarantees
- Guarantees are often written on a percentage of time basis
  - "No worse than 100 Mbps 99.95% of the time"
  - As percentage of time requirement increases, the cost to provide service increases exponentially
  - So SLAs cannot be met 100% of the time

4.5 Service Level Agreements (SLAs)2/3

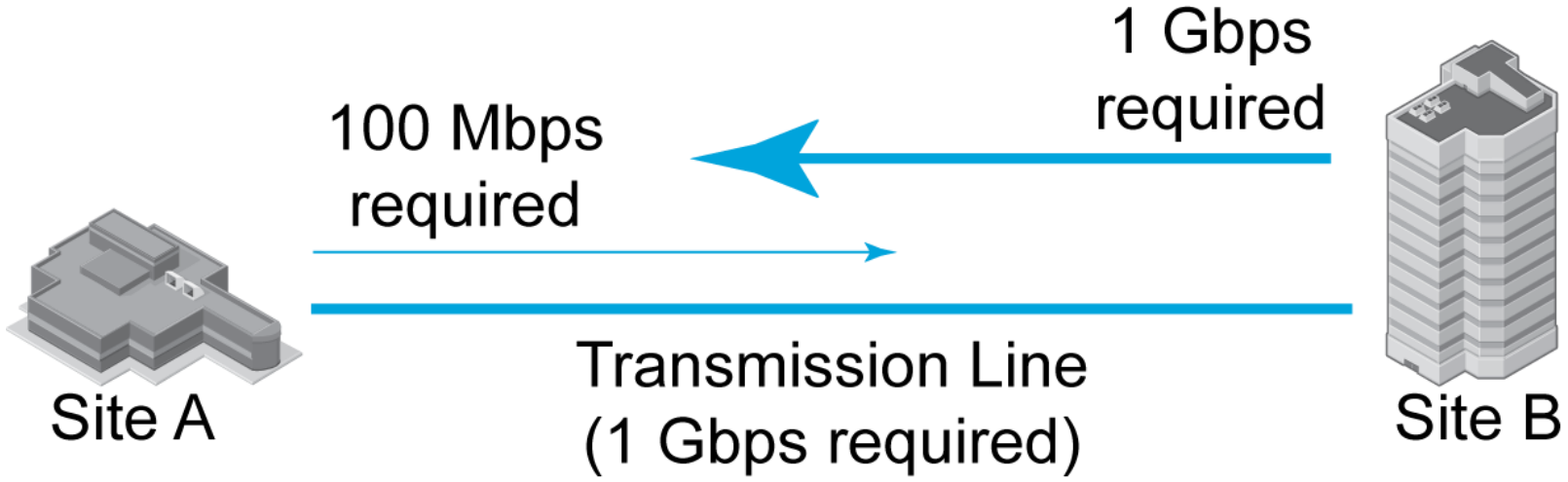
- SLAs specify worst cases (minimum performance to be tolerated)
  - Penalties if worse than the specified performance
  - Example:
    - latency no higher than 50 ms 99.99% of the time
    - Jitter no higher than 2% variation in packet arrival time 99% of the time
    - Availability no lower than 99.99%

4.5 Service Level Agreements (SLAs)3/3

- **Residential services** are rarely sold with SLA guarantees
  - It would be expensive to engineer the network for high-percentage guarantees for residential customers
  - This would make **prices unacceptable**
  - Businesses require high-percentage guarantees and so are willing to pay higher prices

- Failure in the Target Breach
- Cost Matters
- Network Quality of Service QoS
- **Network Design**
- Security Planning Principles
- Centralized Management

4.6 Two-Site Traffic Analysis



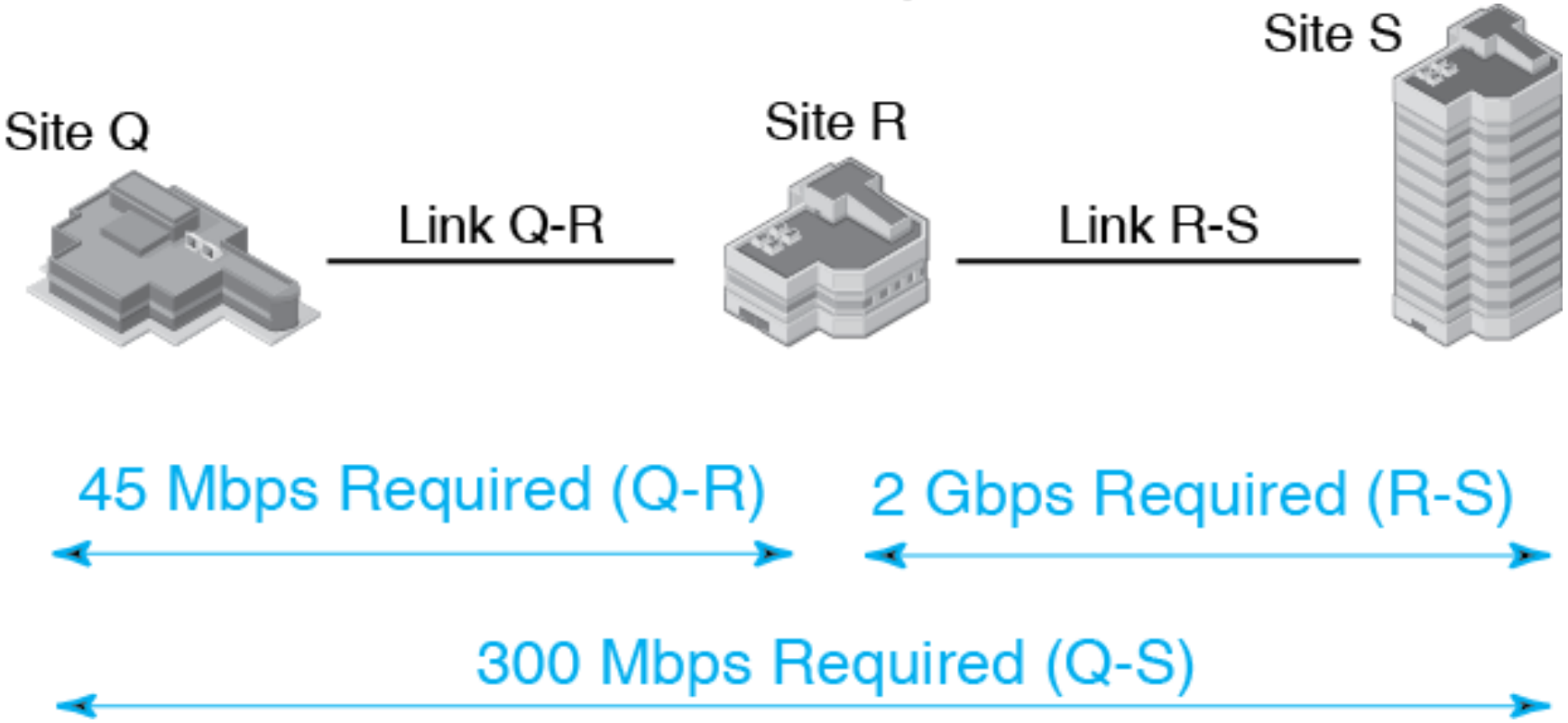
Network design is based on speed requirements

These may be different in the two directions

Most transmission lines are symmetric in speed

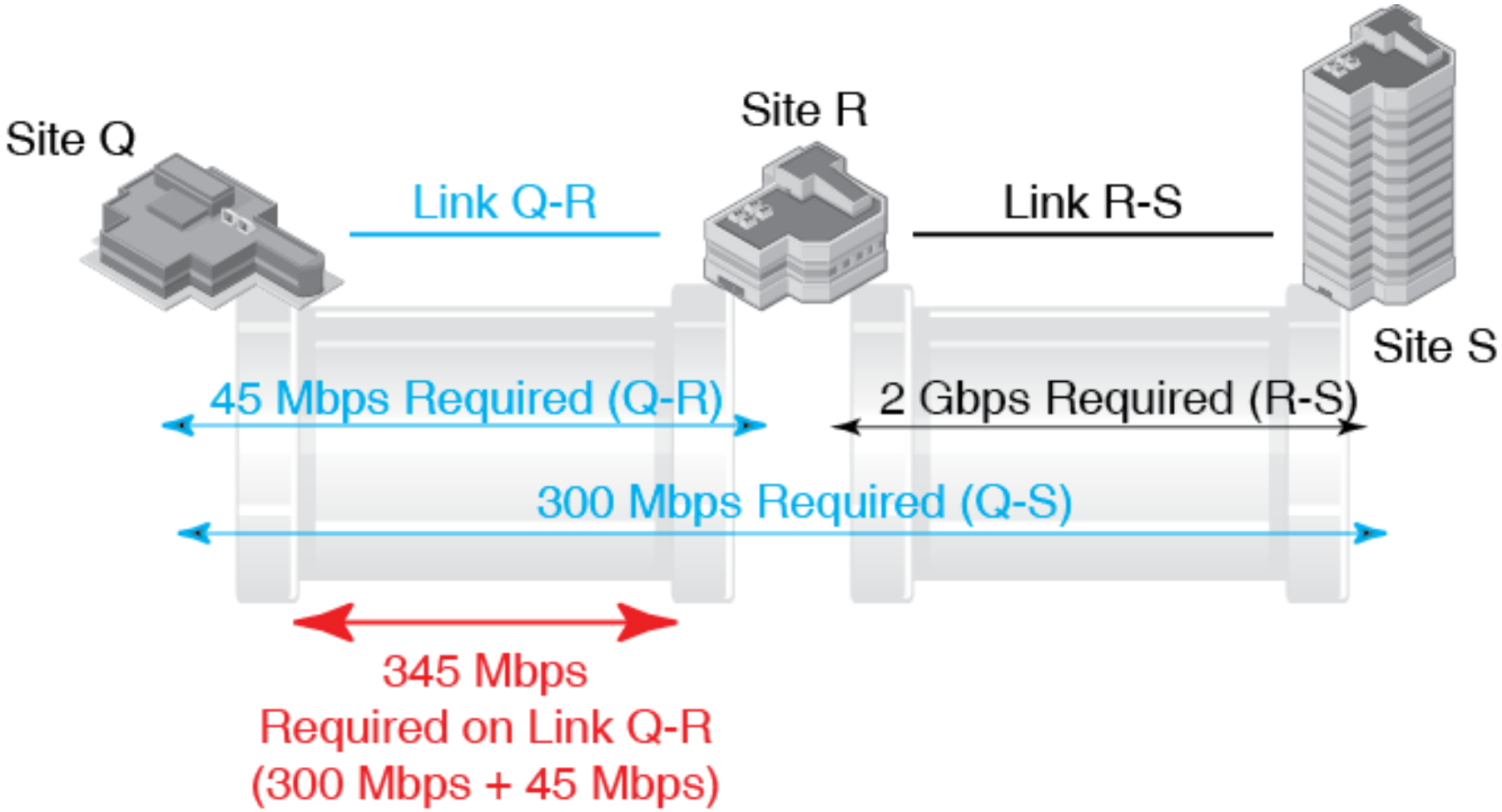
In such cases, the higher-speed dictates line speed

4.7 Three-Site Traffic Analysis

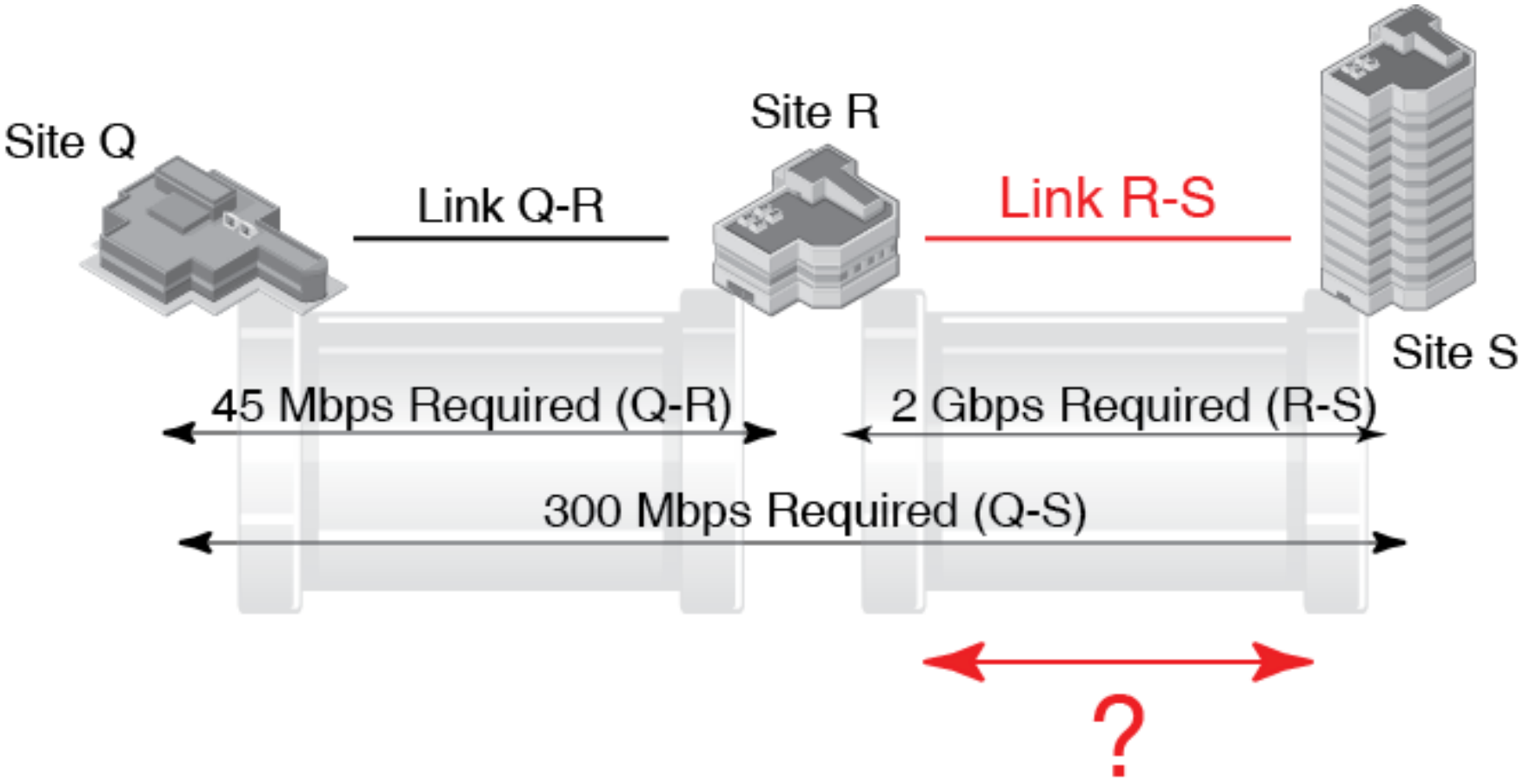


Link QR must carry the traffic flowing between Q and R **and** the traffic flowing between R and S

4.7 Three-Site Traffic Analysis

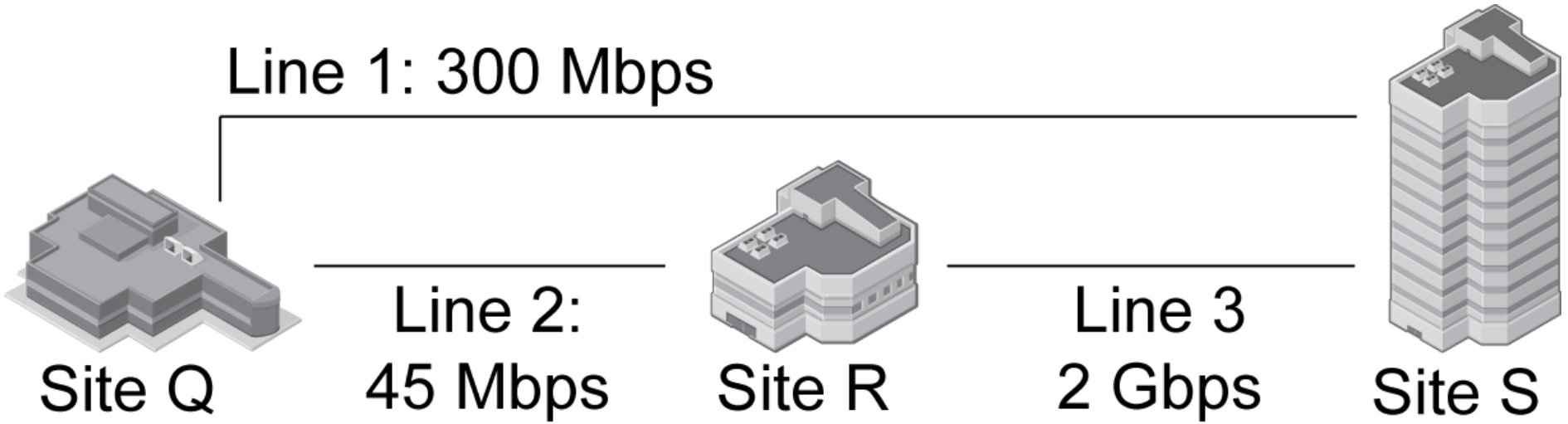


4.7 Three-Site Traffic Analysis



Copyright © 2015 Pearson Education, Ltd.

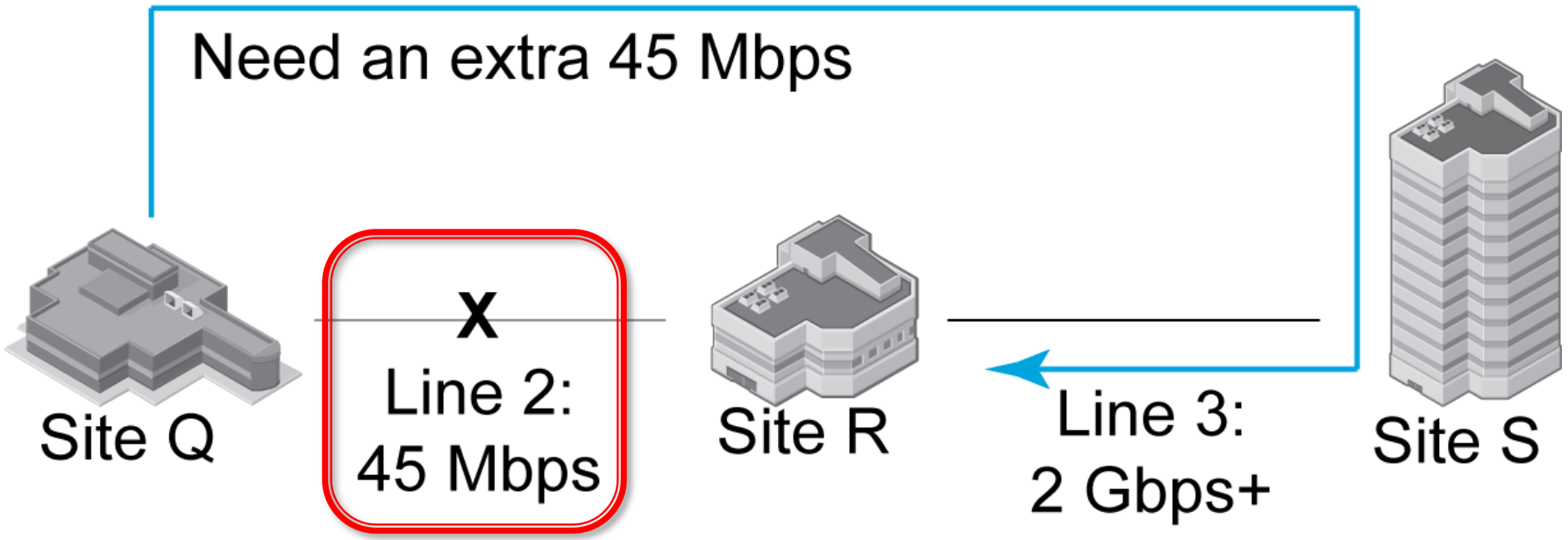
4.8 Three-Site Traffic Analysis with Redundancy



Each pair of sites is connected
Lines only carry traffic between site pairs

4.8 Three-Site Traffic Analysis with Redundancy

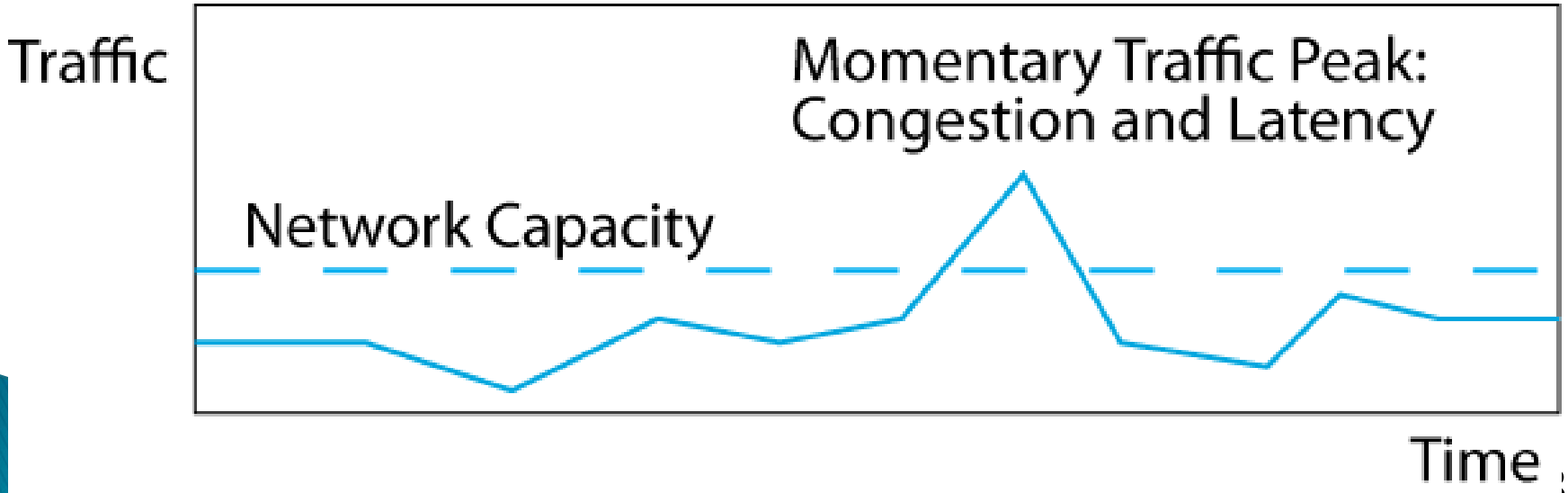
Line 1:
300 Mbps + *45 Mbps* = 345 Mbps



How can traffic get from Q to R?

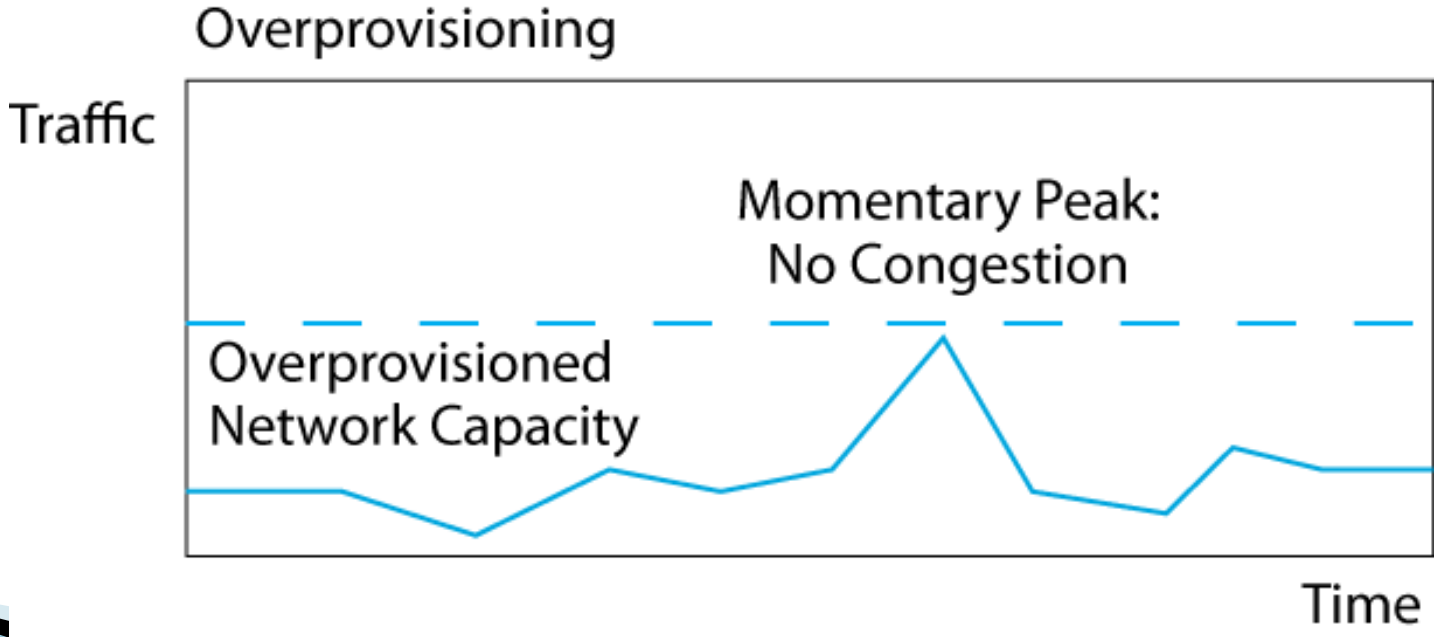
Momentary Traffic Peaks

- Sometimes, there will be momentary traffic peaks above the network's.
- This congestion causes latency because switches and routers must store frames and packets waiting to send them out.
- Buffers are small, so packets are often lost.



Momentary Traffic Peaks
Solution 1: Overprovisioning

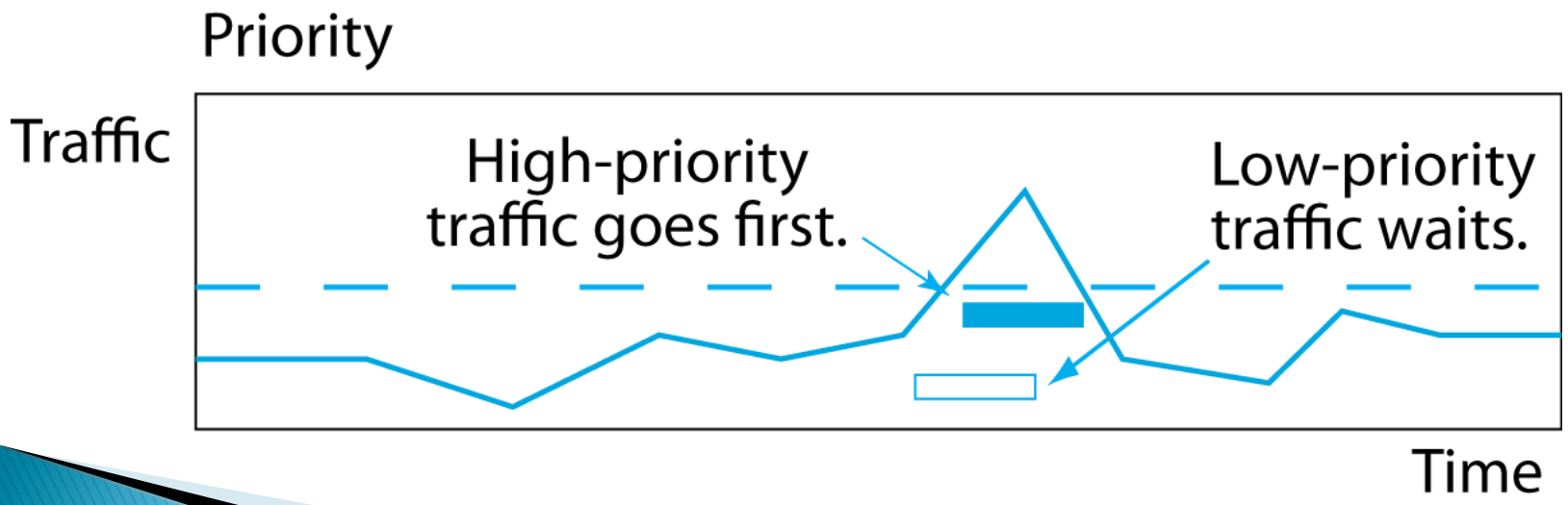
- providing *far* more capacity than the network normally needs.
- This avoids nearly all momentary traffic peaks but is wasteful.



Momentary Traffic Peaks

Solution 2: Priority

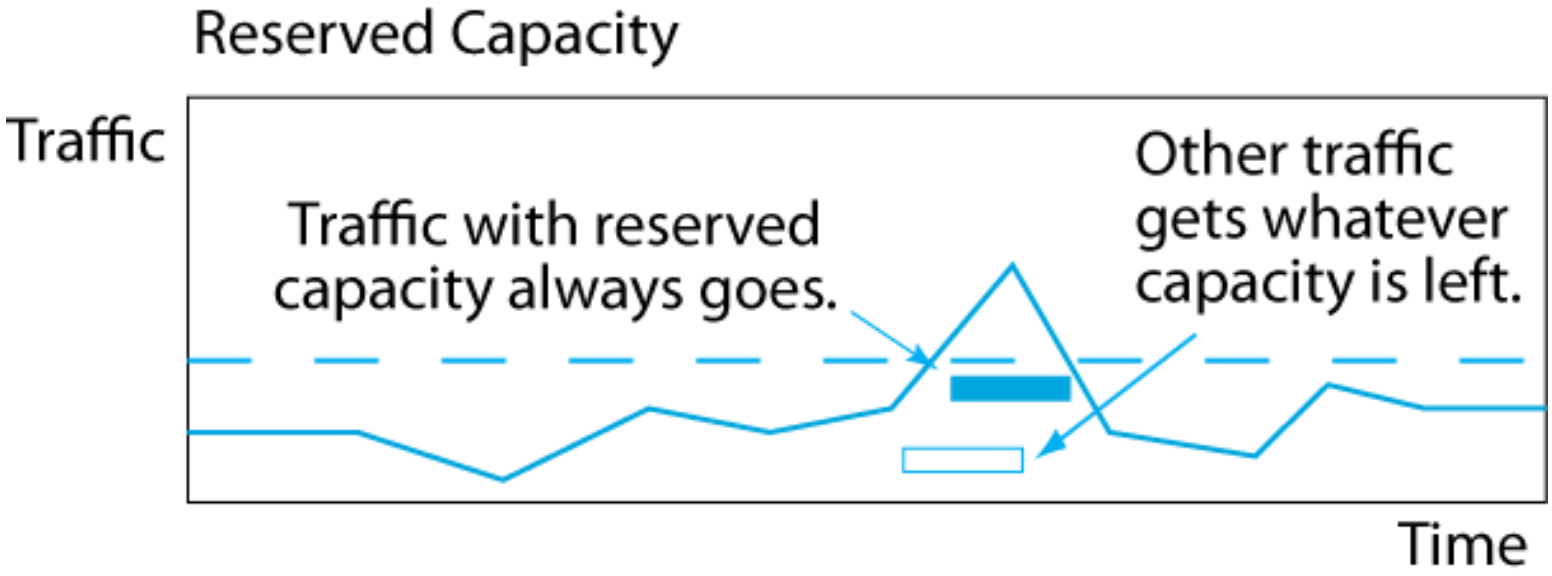
- With priority, latency-intolerant traffic, such as voice, is given high priority and will go first if there is congestion.
- Latency-tolerant traffic, such as e-mail, must wait.
- More efficient than over provisioning; also more labor-intensive.



Momentary Traffic Peaks

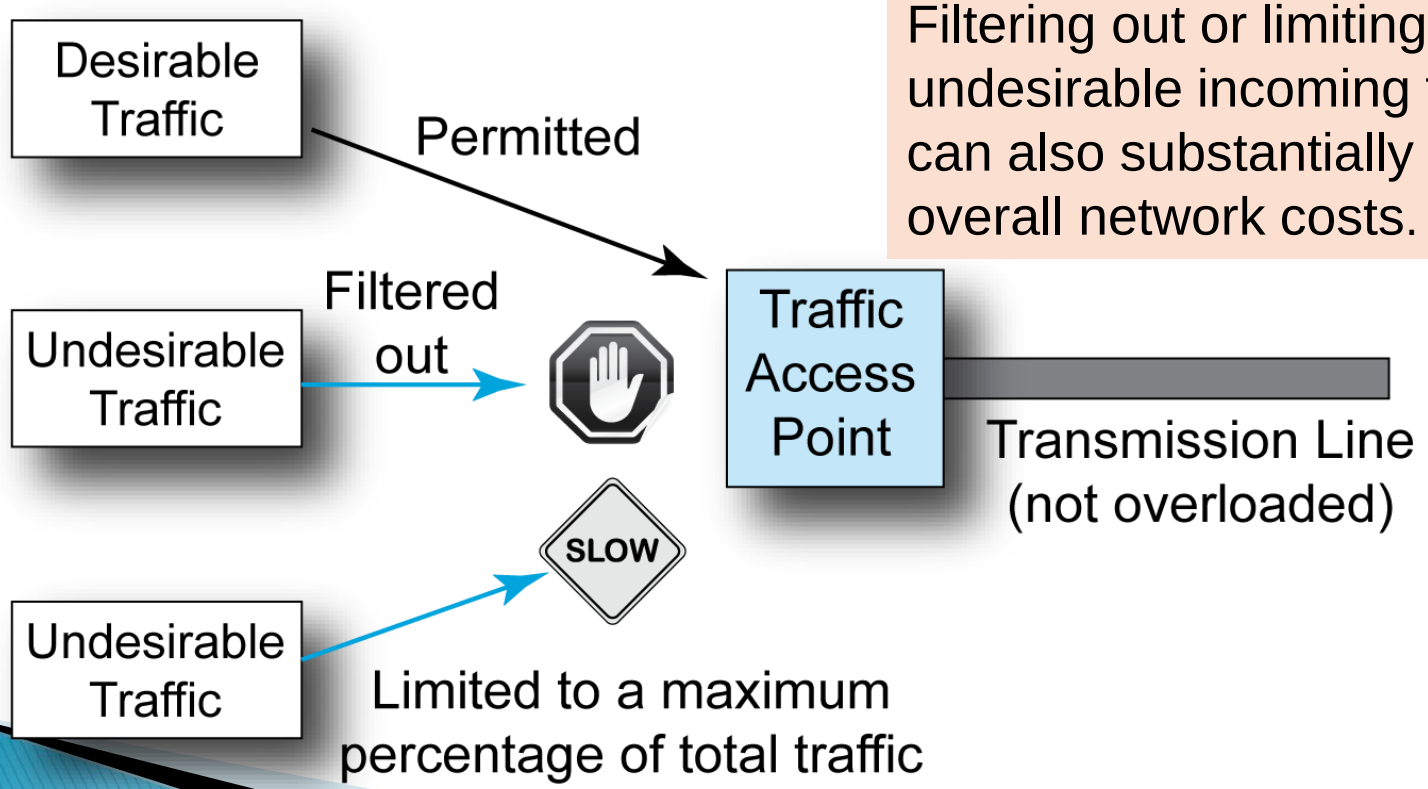
Solution 3: Reservation

- QoS guarantees reserved capacity for some traffic, so this traffic always gets through.
- Other traffic, however, must fight for the remaining capacity.



補充：Traffic Shaping (1/2) -Congestion Prevention

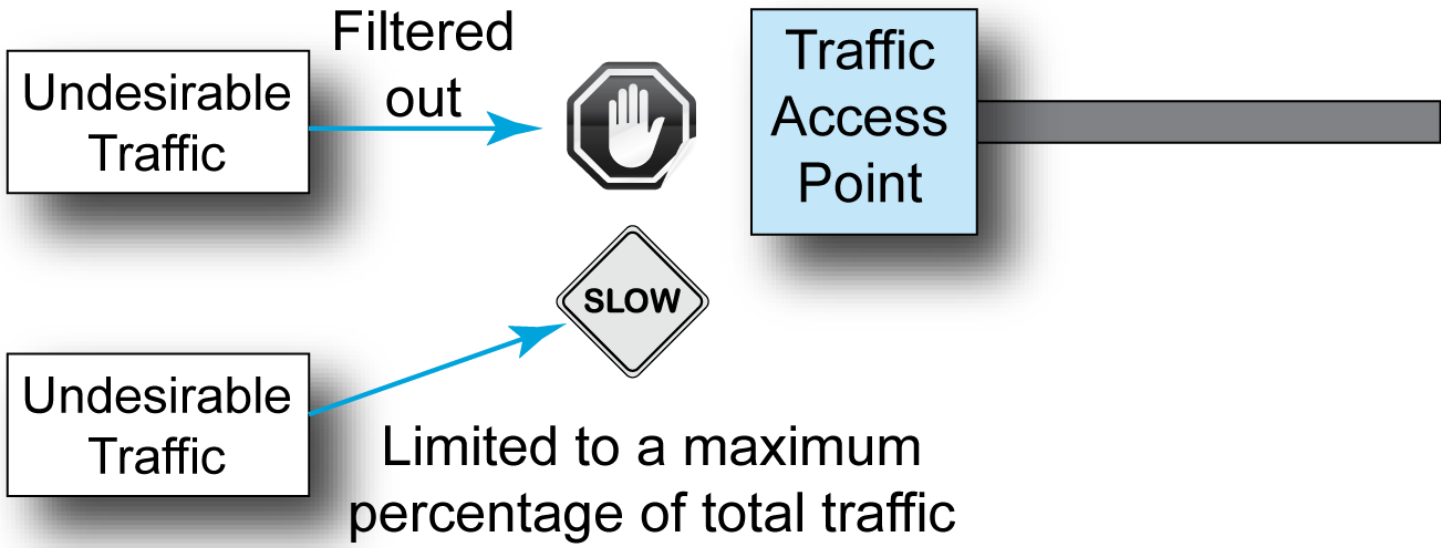
- Over provisioning, priority, and QoS reservations deal with congestion; traffic shaping *prevents* congestion by **limiting incoming** traffic.



Filtering out or limiting undesirable incoming traffic can also substantially reduce overall network costs.

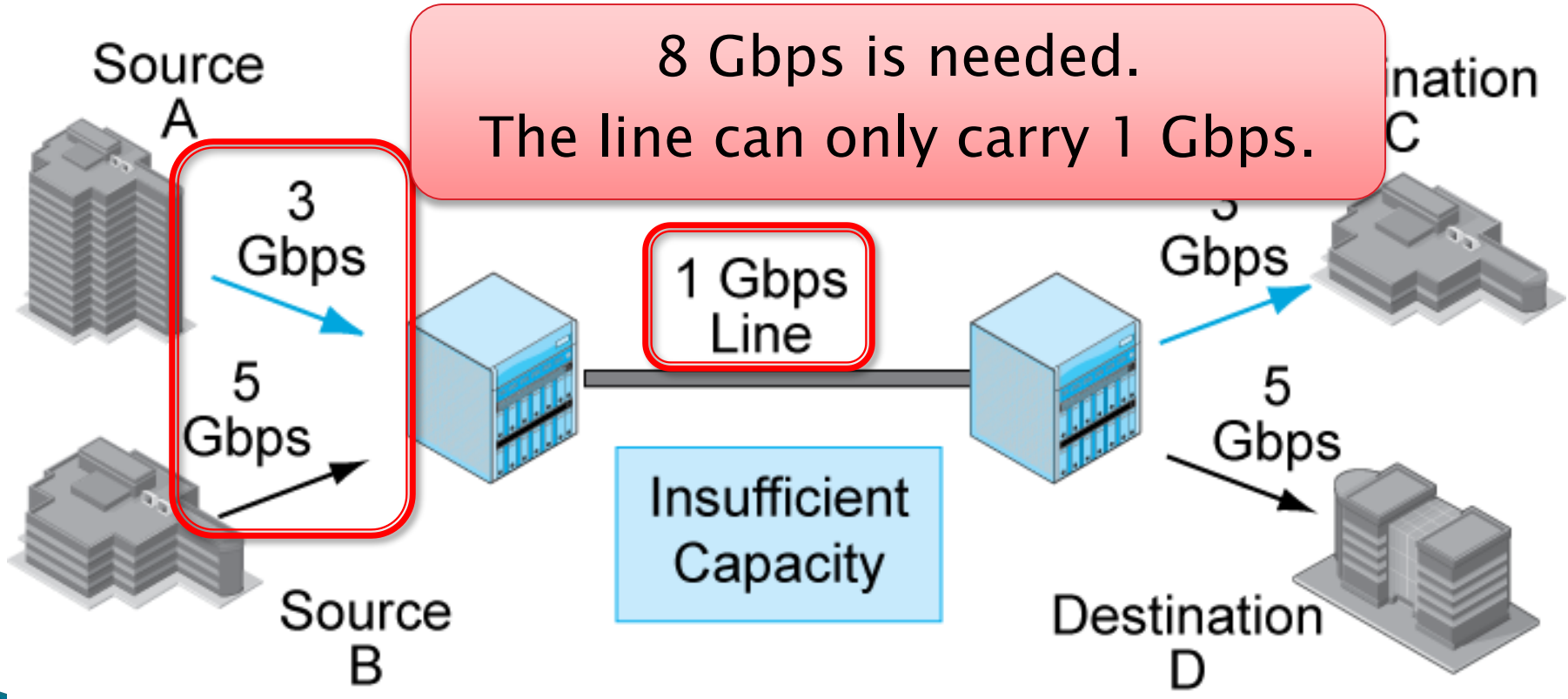
補充： Traffic Shaping (2/2)
-Congestion Prevention

- Some traffic can be banned and simply filtered out.
- Other traffic has both legitimate and illegitimate uses; it can be limited to a certain percentage of traffic.



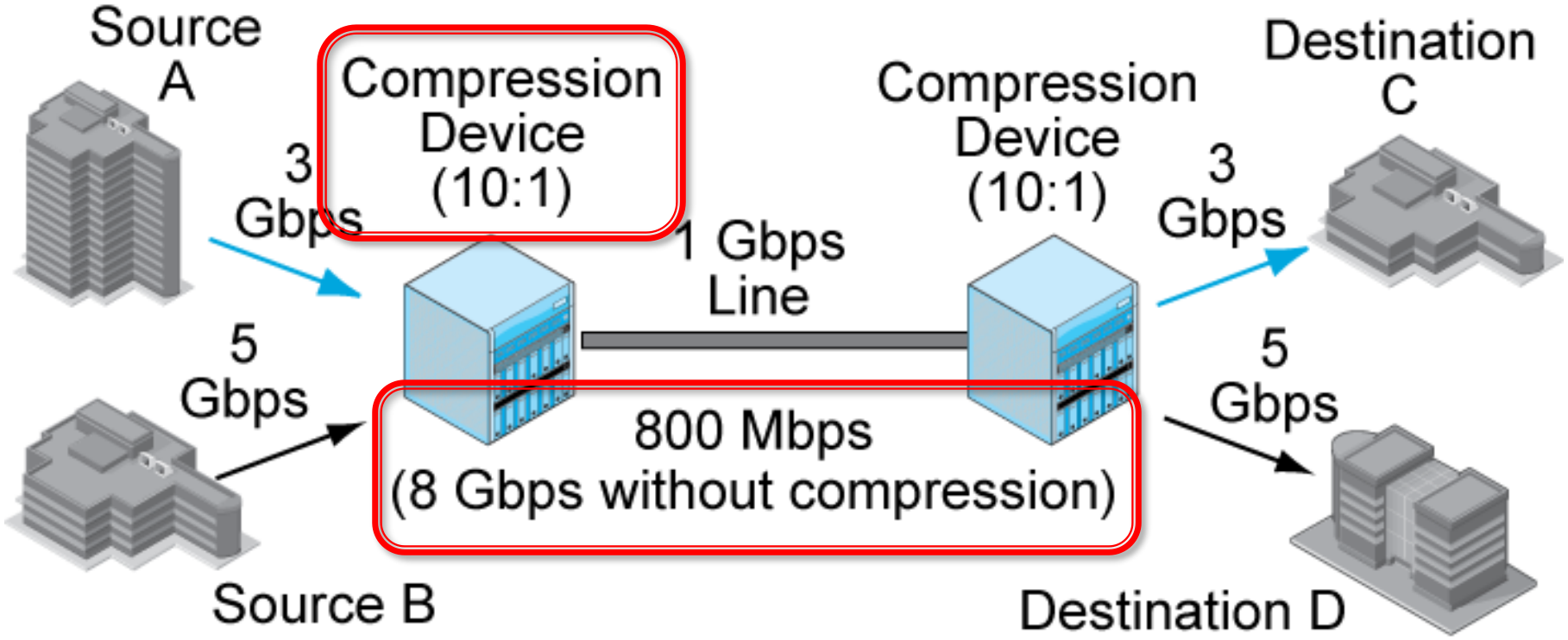
補充： Compression (1/3)

- Compression can help if traffic chronically exceeds the capacity on a line.



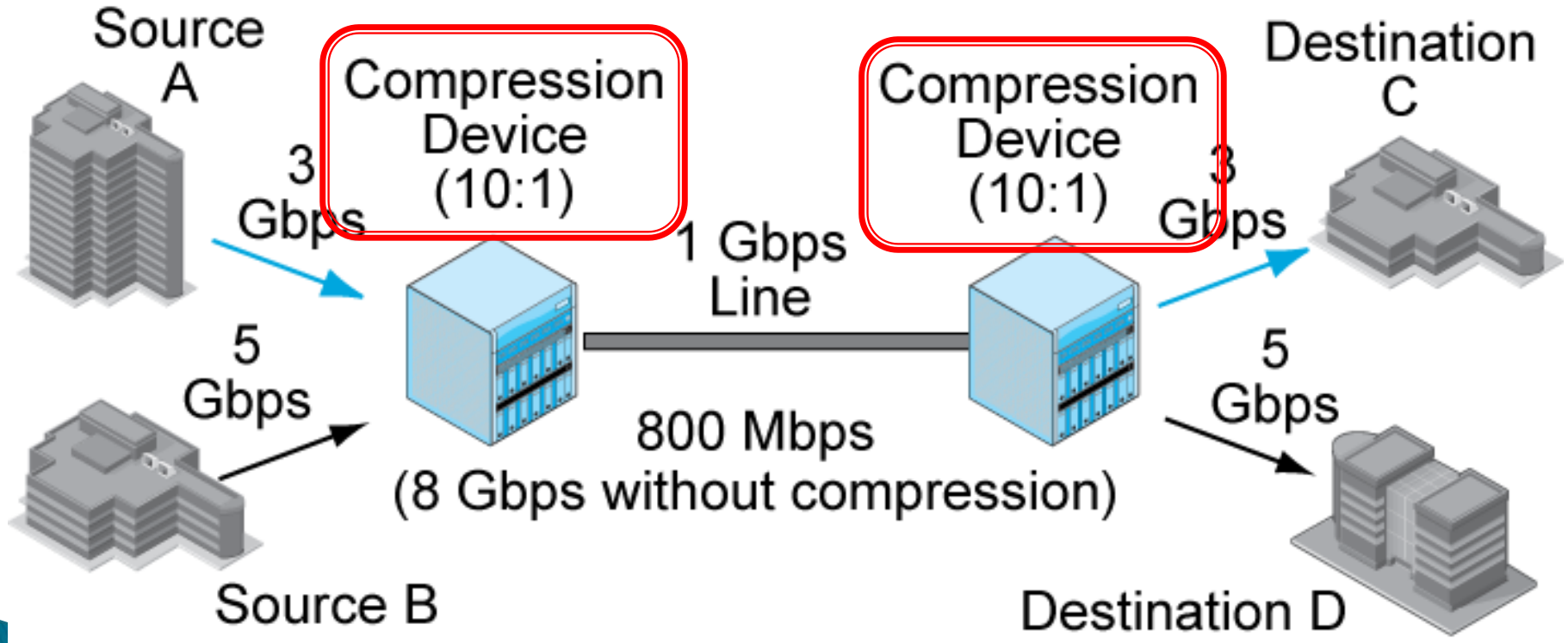
補充： Compression (2/3)

- Data often contains redundancies and can be compressed.



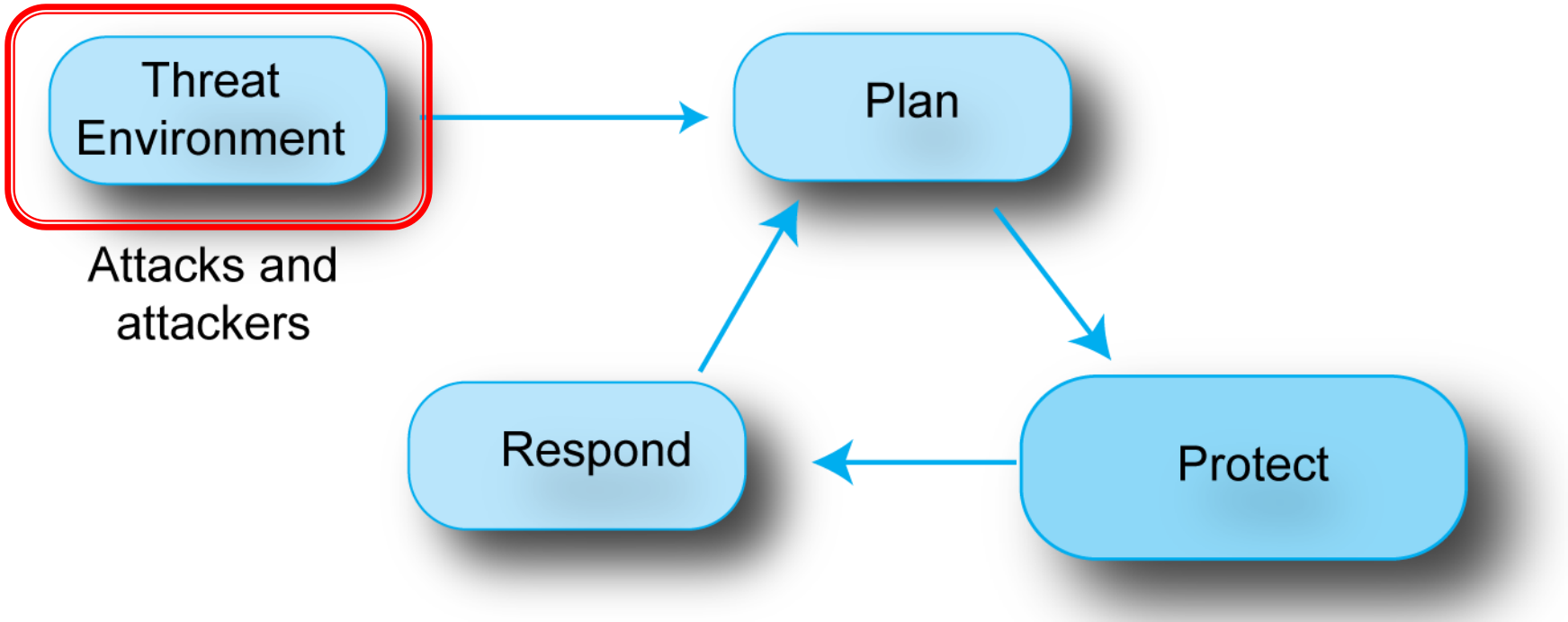
補充： Compression (3/3)

- Must have compatible compression equipment at the two ends of the line.



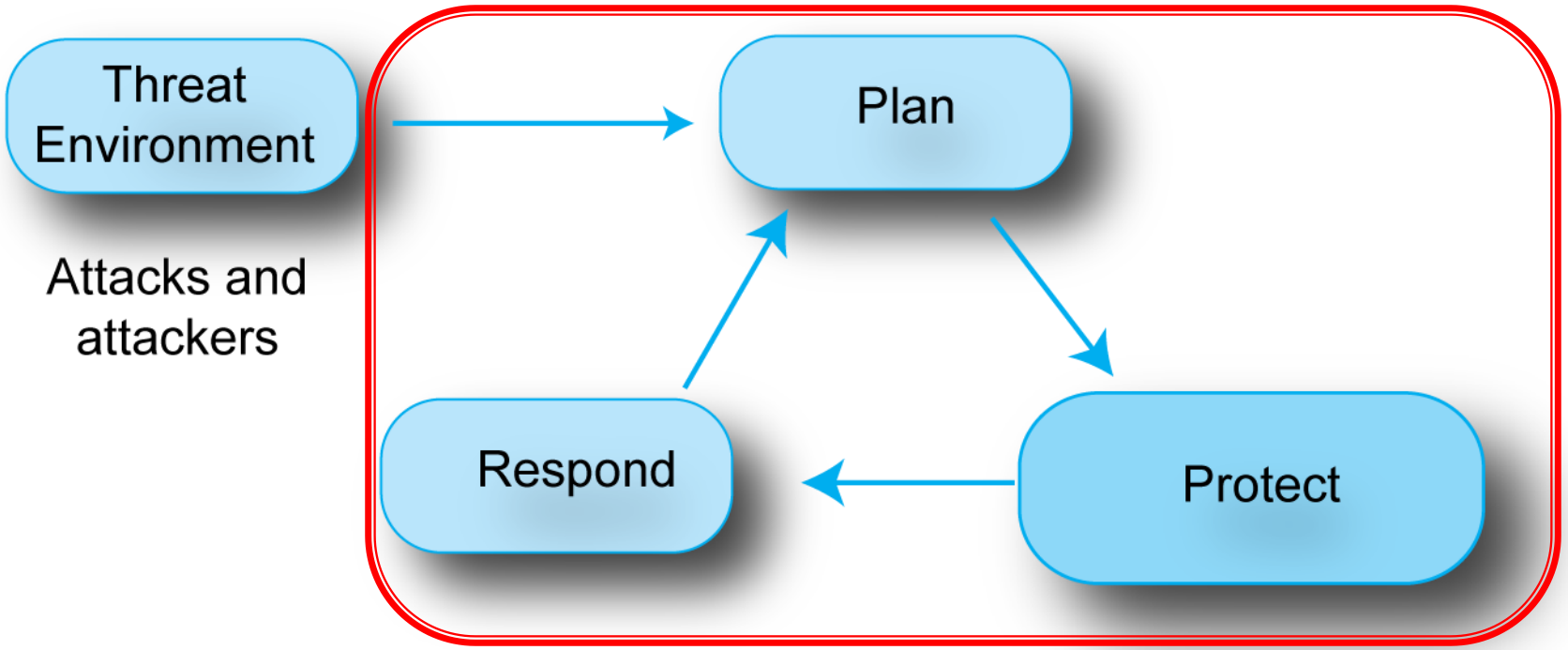
- Failure in the Target Breach
- Cost Matters
- Network Quality of Service QoS
- Network Design
- **Security Planning Principles**
- Centralized Management

4.10 Threat Environment



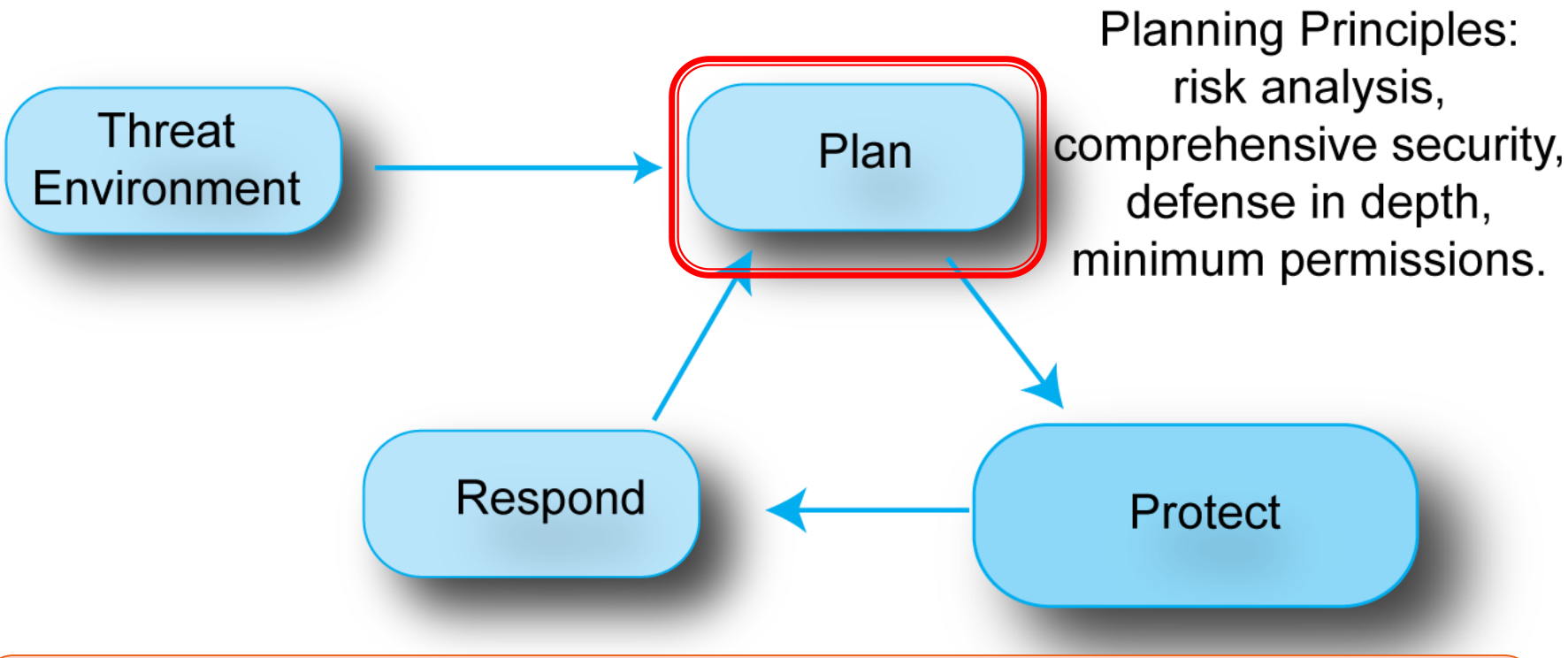
You cannot defend yourself unless you know the threat environment you face.

4.10 Plan-Protect-Respond



Companies defend themselves with a process called the Plan-Protect-Respond Cycle.

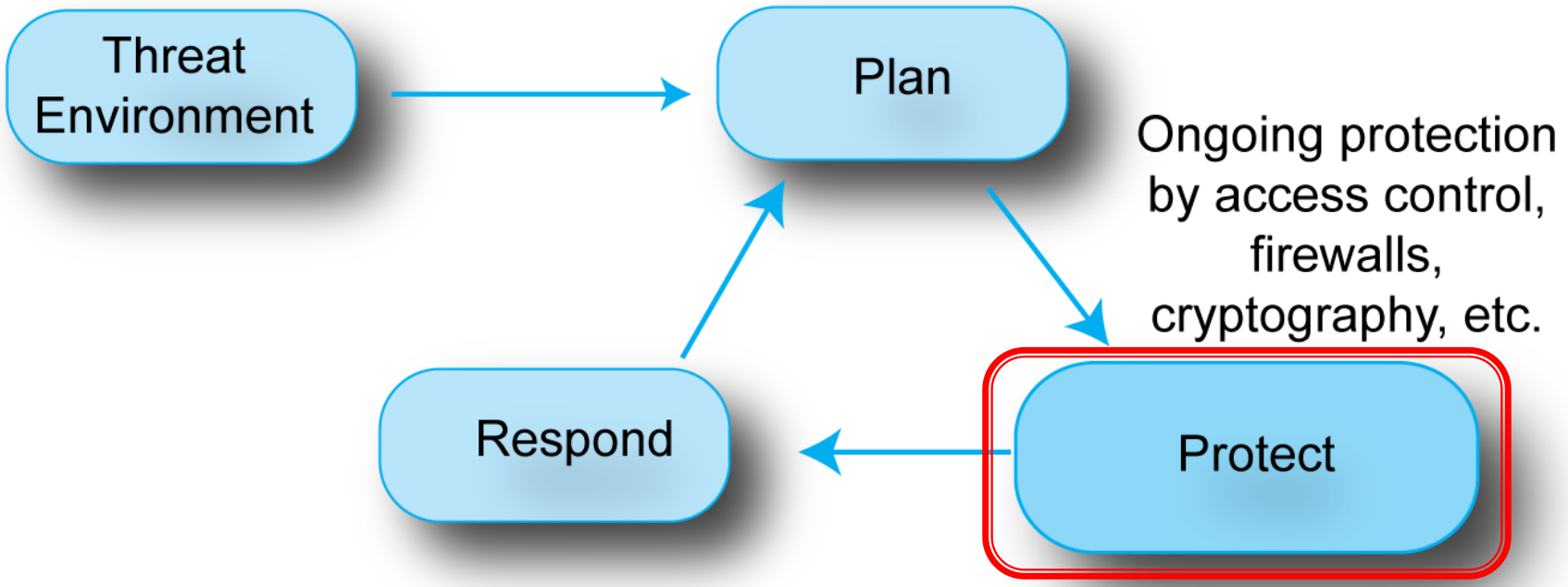
4.10 Planning



The Plan-Protect-Respond Cycle starts with Planning.

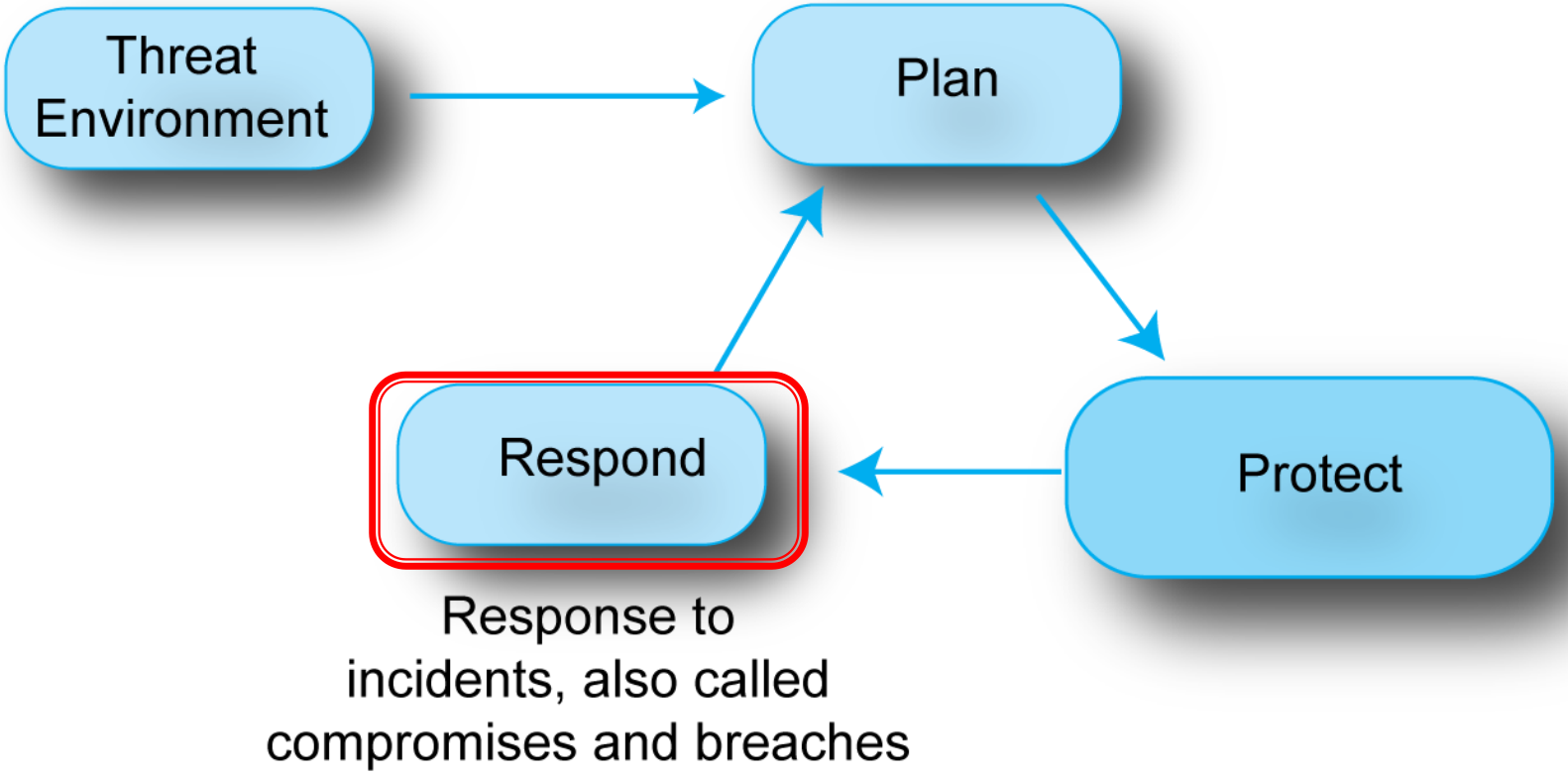
We will look at important planning principles.

4.10 Protecting



Companies spend most of their security effort on the protection phase, in which they apply planned protections on a daily basis.
We covered this phase in Chapter 3.

4.10 Response

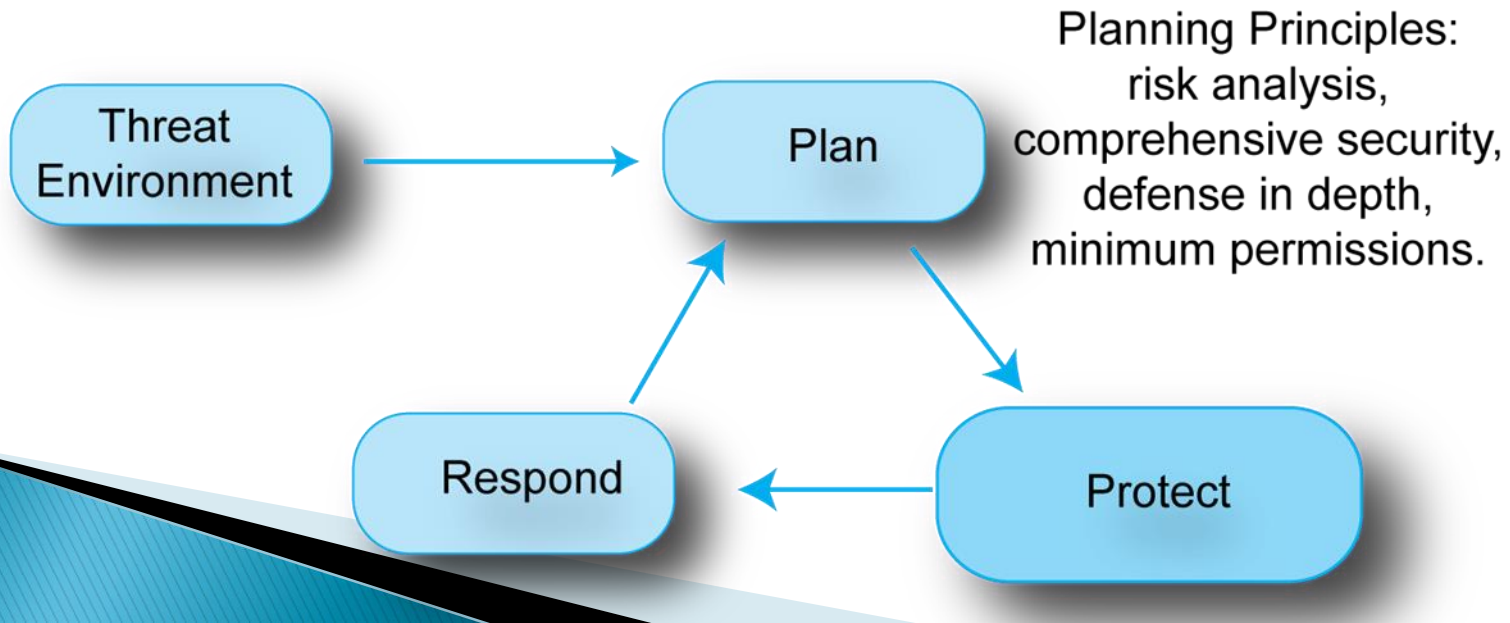


Response to incidents, also called compromises and breaches

Even with great planning and protection, incidents will happen, and a company must have a well-rehearsed plan for responding to them.

4.11 Security Planning Principles

- **Security Is a Management Issue, Not a Technology Issue**
  - Without good management, technology cannot be effective
  - A company must have good security processes



4.11 Security Planning Principles

- Security Planning Principles
  - **Risk analysis**
  - **Comprehensive security**
  - **Defense in depth**
  - **Weakest link analysis**
  - **Single points of takeover**
  - **Least permissions in access control**

4.11 Risk Analysis



- Security Planning Principles
  - Risk Analysis
    - The process of balancing threat and protection costs for individual assets.
    - Annual cost of protection should not exceed the expected annual damage.
      - If probable annual damage is $10,000 and the annual cost of protection is $200,000, protection should not be undertaken.
    - Goal is not to eliminate risk but to reduce it in an economically rational level.

4.12: Risk Analysis Calculation

Countermeasure	None	A
Damage per successful attack	$1,000,000	$500,000
Annual probability of a successful attack	20%	20%
Annual probability of damage	$200,000	$100,000
Annual cost of countermeasure	$0	$20,000
Net annual probable outlay	$200,000	$120,000
A		0
A		s

Countermeasure A
cuts the damage per successful attack in half,
but does not change the annual probability of occurrence.

3.10 Risk Analysis Calculation

Countermeasure	None	A
Dam	$1,000,000	$500,000
Ann attack		20%
Annual probability of damage	$200,000	$100,000
Annual cost of countermeasure	$0	$20,000
Net annual probable outlay	$200,000	$120,000
Annual value of countermeasure		$80,000
Adopt the countermeasure?		Yes

Countermeasure A
Will have a net savings of $80,000 per year.

3.10 Risk Analysis Calculation

Countermeasure	None	B
Damage per successful attack	$1,000,000	$1,000,000
Annual probability of a successful attack	20%	15%
Annual probability of damage	$200,000	$150,000
Annual cost of countermeasure	$0	**$60,000**

Countermeasure B
cuts the frequency of occurrence in half,
but does not change the damage per occurrence.

3.10 Risk Analysis Calculation

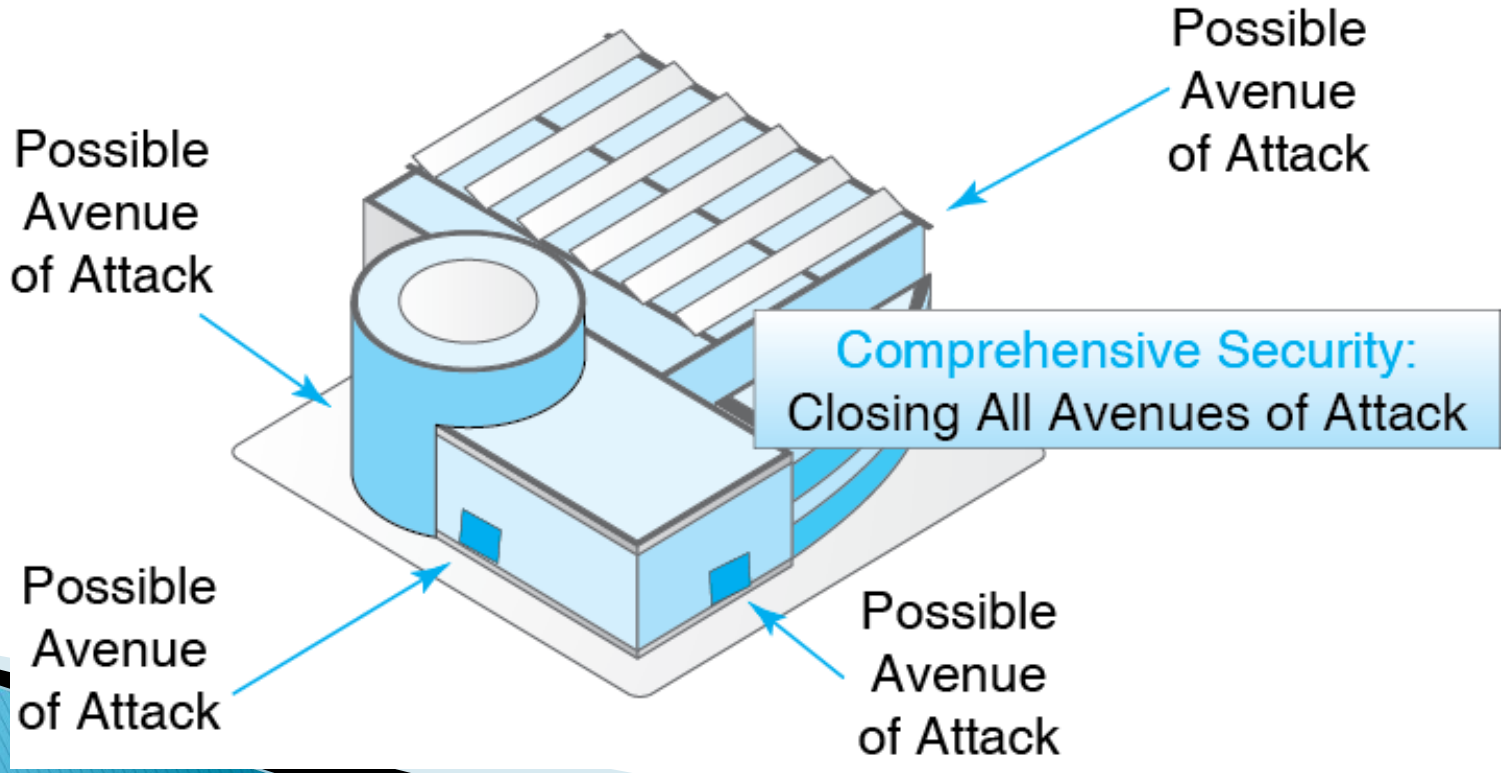
Countermeasure	None	B
Damage per successful attack	$1,000,000	**$1,000,000**
Annual probability of damage	$200,000	$150,000
Annual cost of countermeasure	$0	**$60,000**
Net annual probable outlay	$200,000	$210,000
Annual value of countermeasure		-$10,000
Adopt the countermeasure?		**No**

This time, the countermeasure is too expensive.

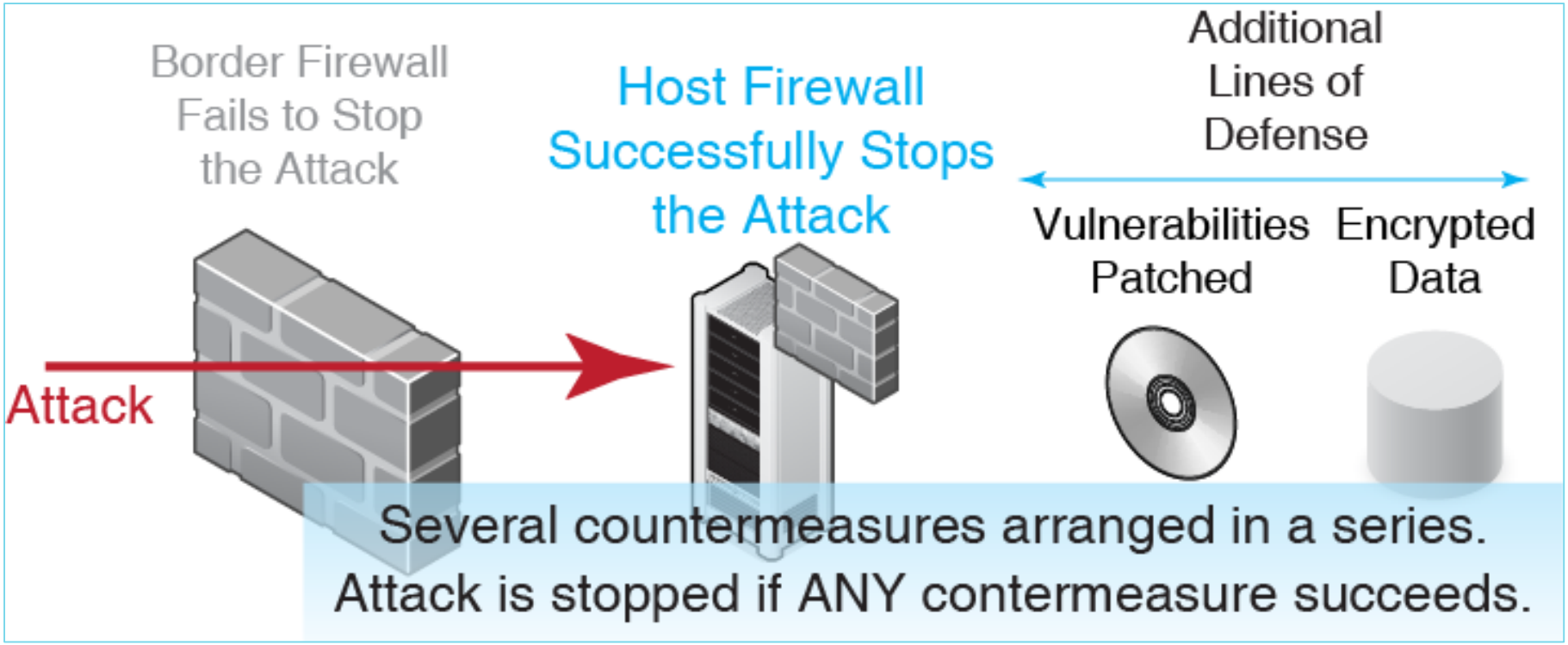
4.13 Comprehensive Security



1. An attacker only has to find one weakness to succeed.
2. A firm needs to close off all avenues of attack
3. This requires very good planning.



4.14 Defense in Depth





4.15 Identifying Weakest Links

Firewall Hardware



Firewall Software



Defective Firewall ACL



Firewall Log File



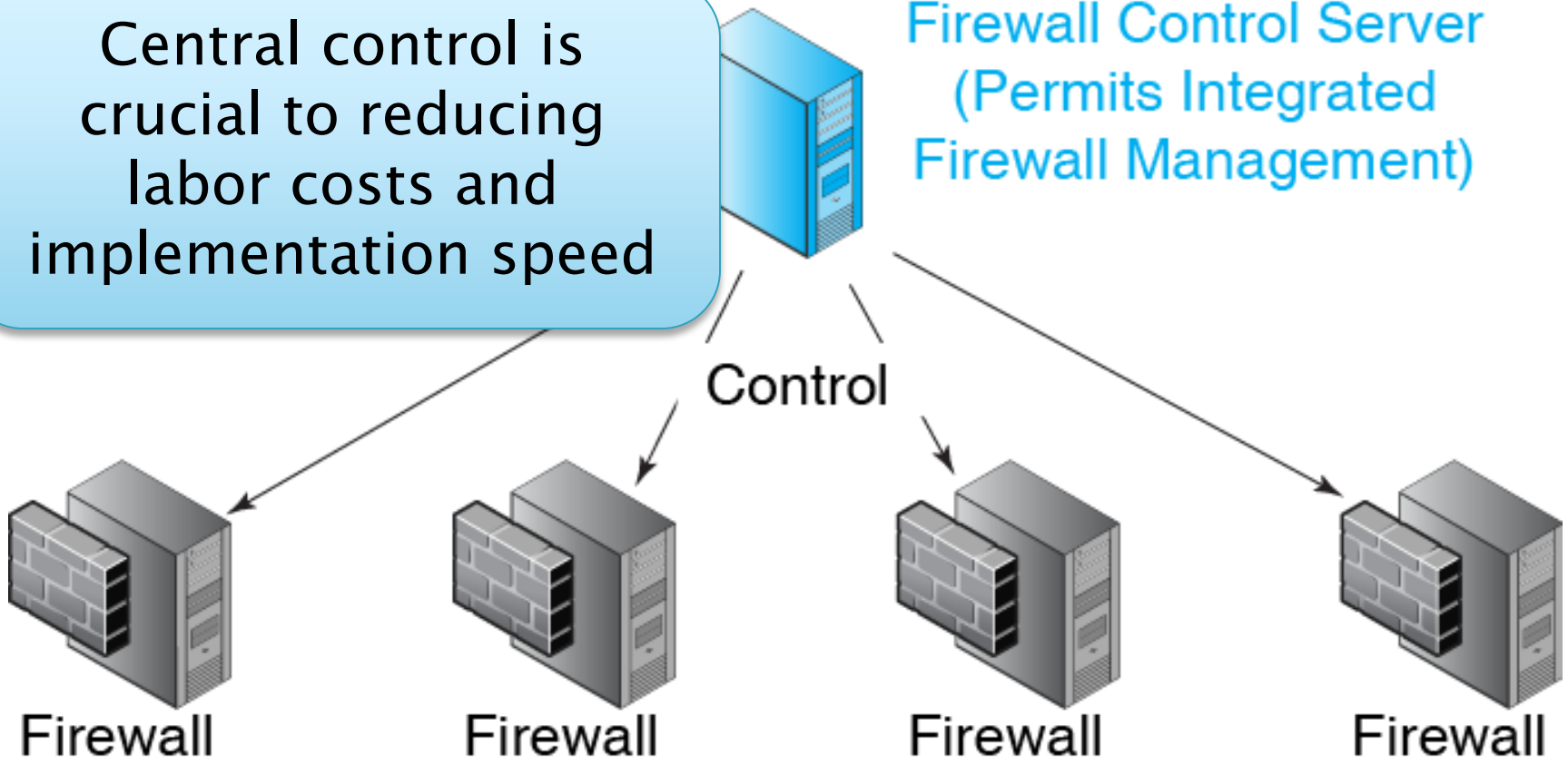
Reading Log File Frequently



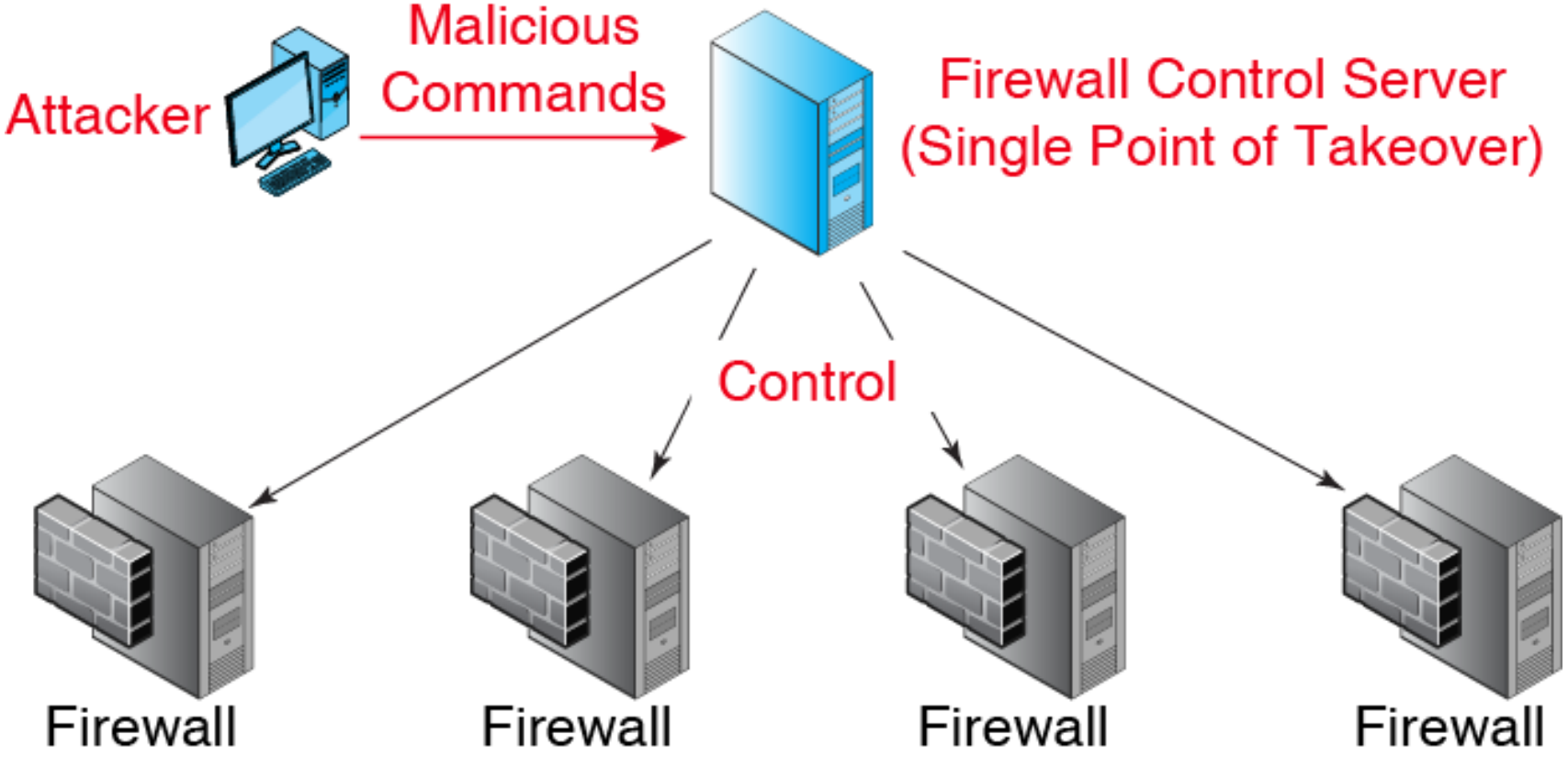
A Single Countermeasure with Multiple Components
ALL Components Must Work or an Attack Will Succeed.

4.16 Protecting Single Points of Take-Over (1/2)

Central control is crucial to reducing labor costs and implementation speed



4.16 Protecting Single Points of Take-Over (2/2)



4.17 Least Permissions in Access Control

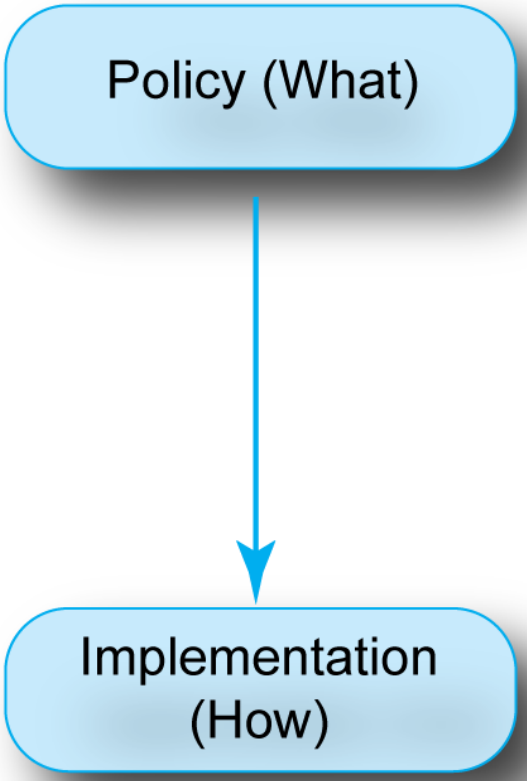
- **Access control** is limiting who may have access to each resource and limiting his or her permissions when using the resource
- **Authentication** versus **Authorizations** (Permissions)
  - Authentication: Proof of identity
  - Authorizations: Permissions a particular authorized user is given with a resource
  - Just because a user is authenticated does not mean that he or she will be permitted to do everything

4.17 Least Permissions in Access Control

- Principle of Least Permissions
  - Give each authenticated user only the minimum permissions he or she needs to do his or her job
  - Cannot do unauthorized things that will compromise security
- Examples of Limited Permissions
  - Create files but not delete files
  - Read files but not write (edit) them
  - Connect to the person's department server but not to the Finance server

Copyright © 2015 Pearson Education, Ltd.

Policy-Based Security (1/6)



Planners create policies, which specify what to do but not how to do it.

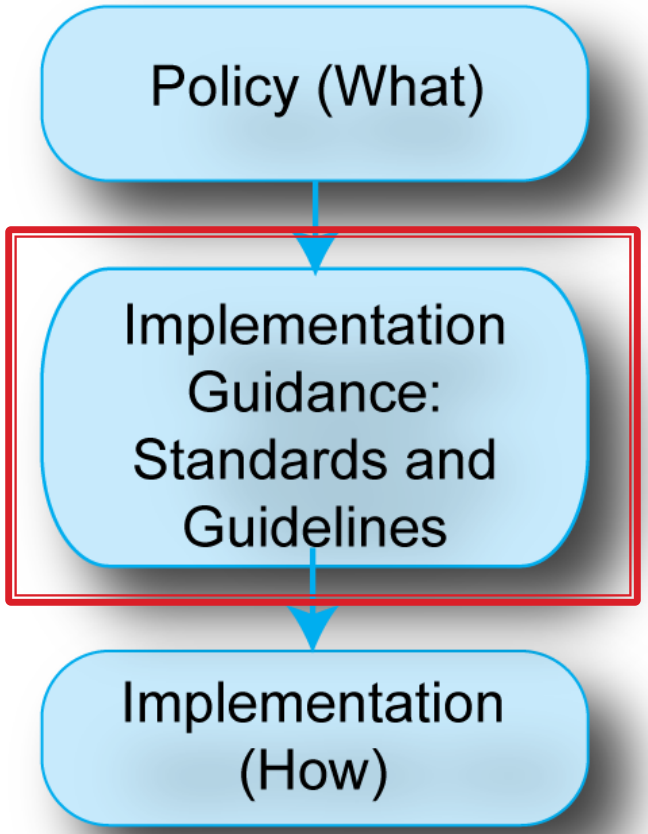
Policy-makers create policies with global knowledge.

Implementers implement policies with local and technical expertise.

4.18 Policy-Based Security

- Policy Example
  - Use strong encryption for credit cards.
- Implementation of the Policy
  - Choose a specific encryption method within this policy.
  - Select where in the process to do the encryption.
  - Choose good options for the encryption method.

4.18 Policy-Based Security

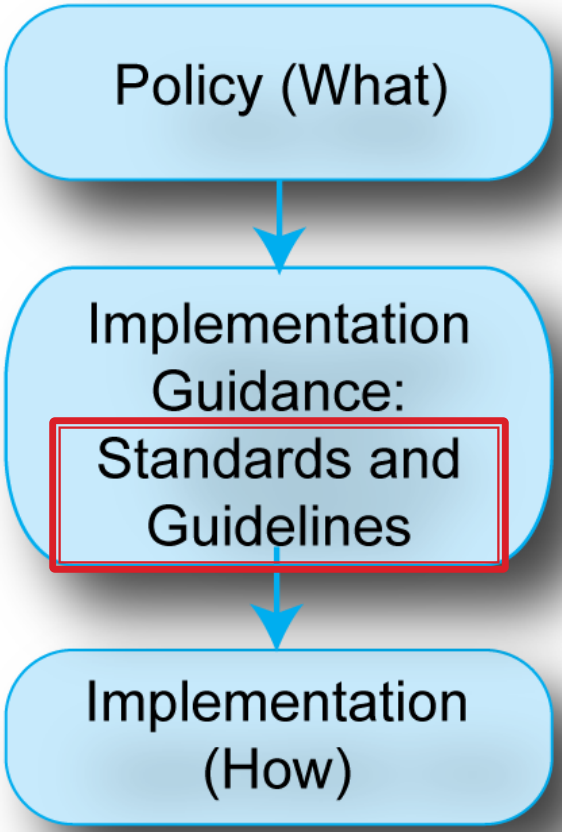


Implementation guidance goes beyond pure "what" by constraining to some extent the "how".

For example, it may specify that encryption keys must be more than 100 bits long.

Constrains implementers so they will make reasonable choices.

4.18 Policy-Based Security

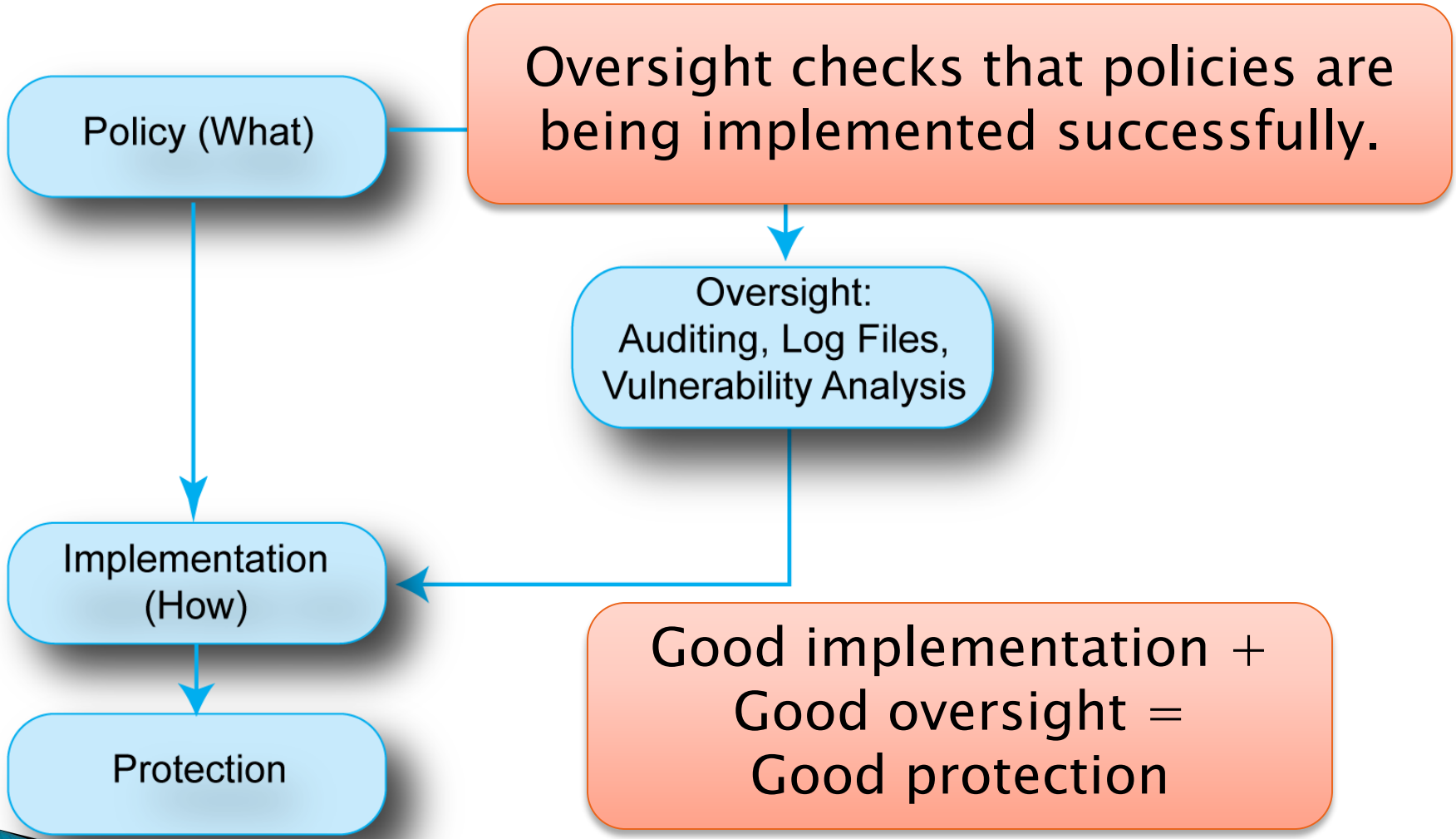


Implementation Guidance has two forms.

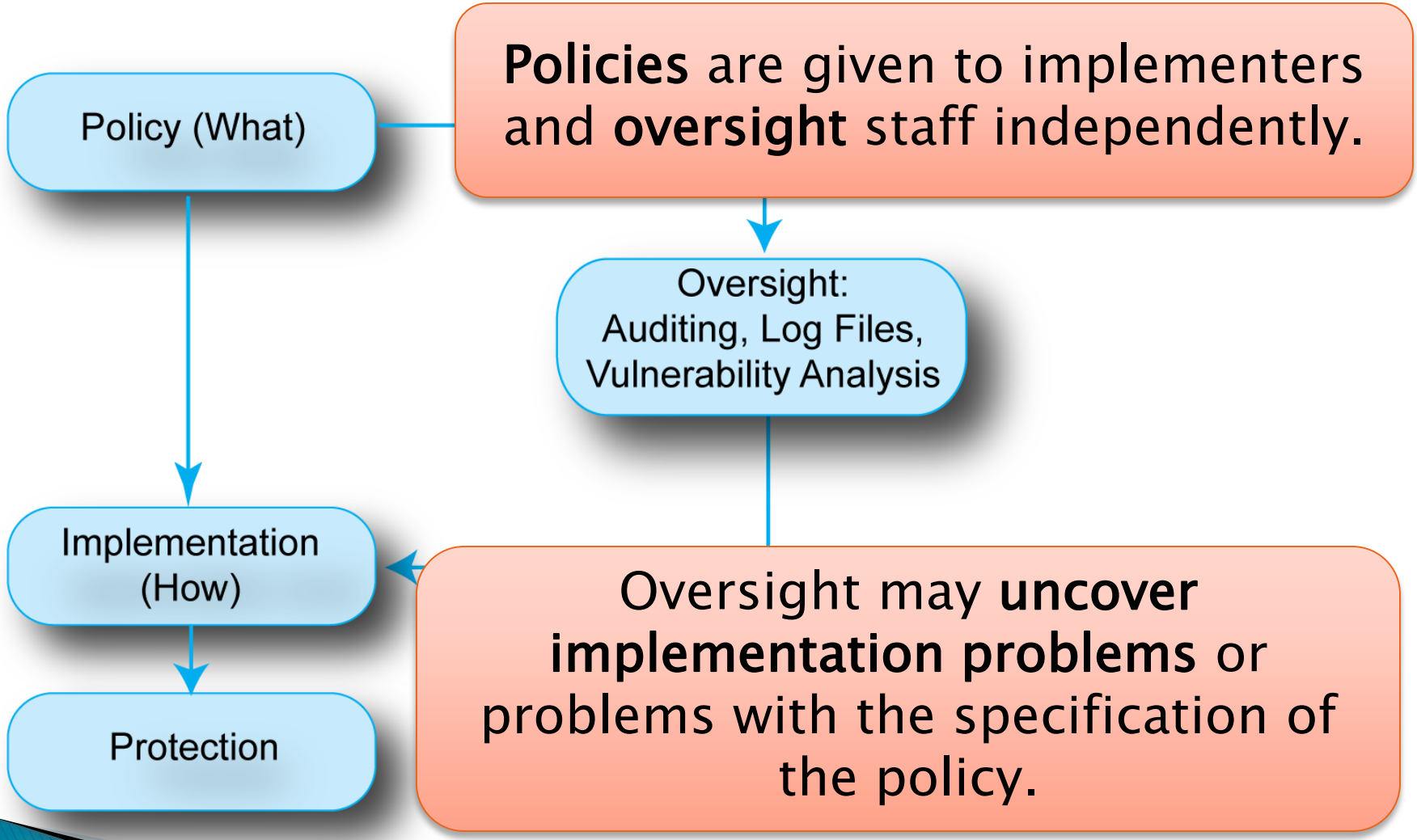
Standards MUST be followed by implementers.

Guidelines SHOULD be followed, but are optional. However, guidelines must be considered carefully.

4.18 Policy-Based Security



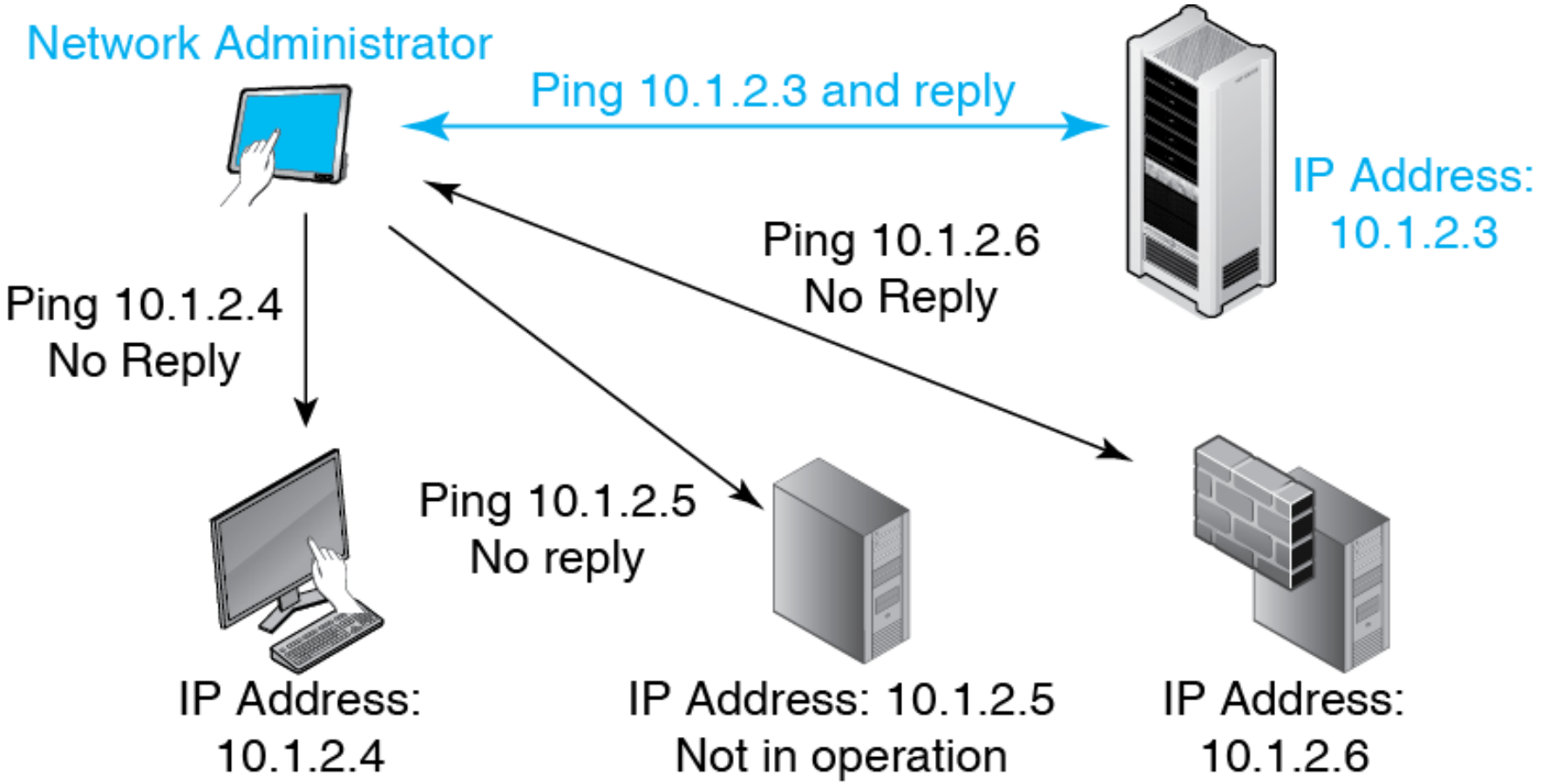
4.18 Policy-Based Security



- Failure in the Target Breach
- Cost Matters
- Network Quality of Service QoS
- Network Design
- Security Planning Principles
- **Centralized Management**

Copyright © 2015 Pearson Education, Ltd.

4.19 Ping



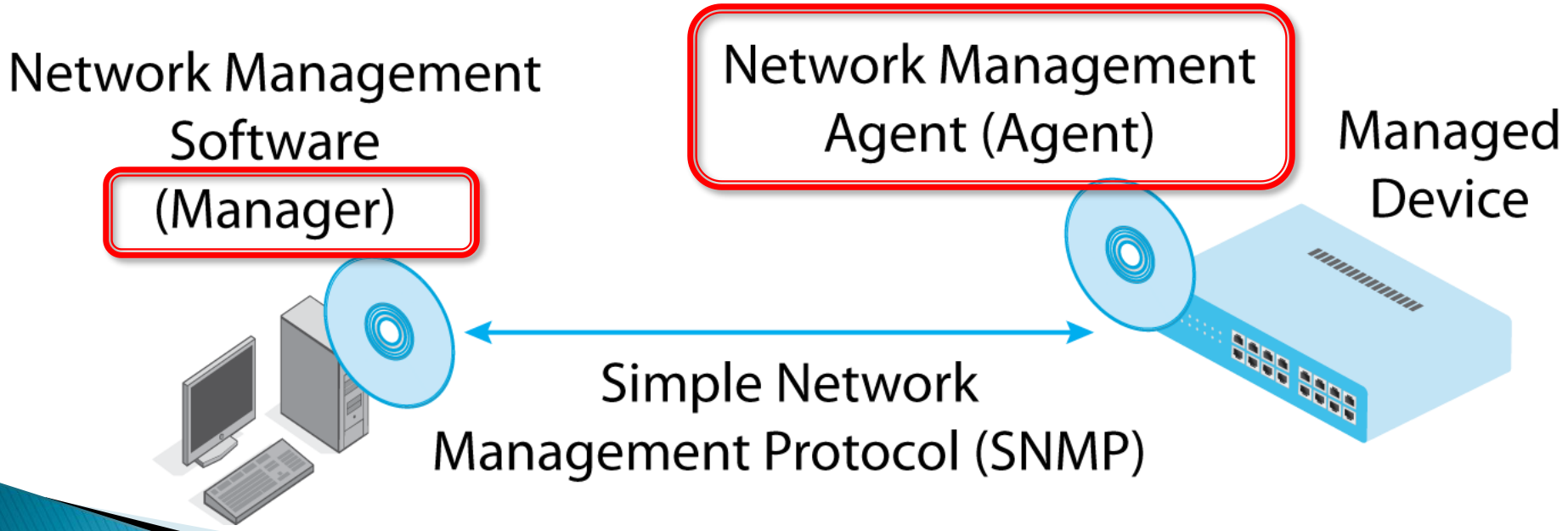
Copyright © 2015 Pearson Education, Ltd.

4.20: Simple Network Management Protocol (SNMP)

- network visibility—to know the status of all devices at all times.
- SNMP is designed to collect information needed for network visibility.
  1. for remotely managing network devices from a **centralized device**
  2. avoid the expense of **traveling to** many devices
  3. **standardizes** remote management communication
  4. Optionally, allows the network administrator to **reconfigure remote devices**
  5. Potential for large labor **cost savings**

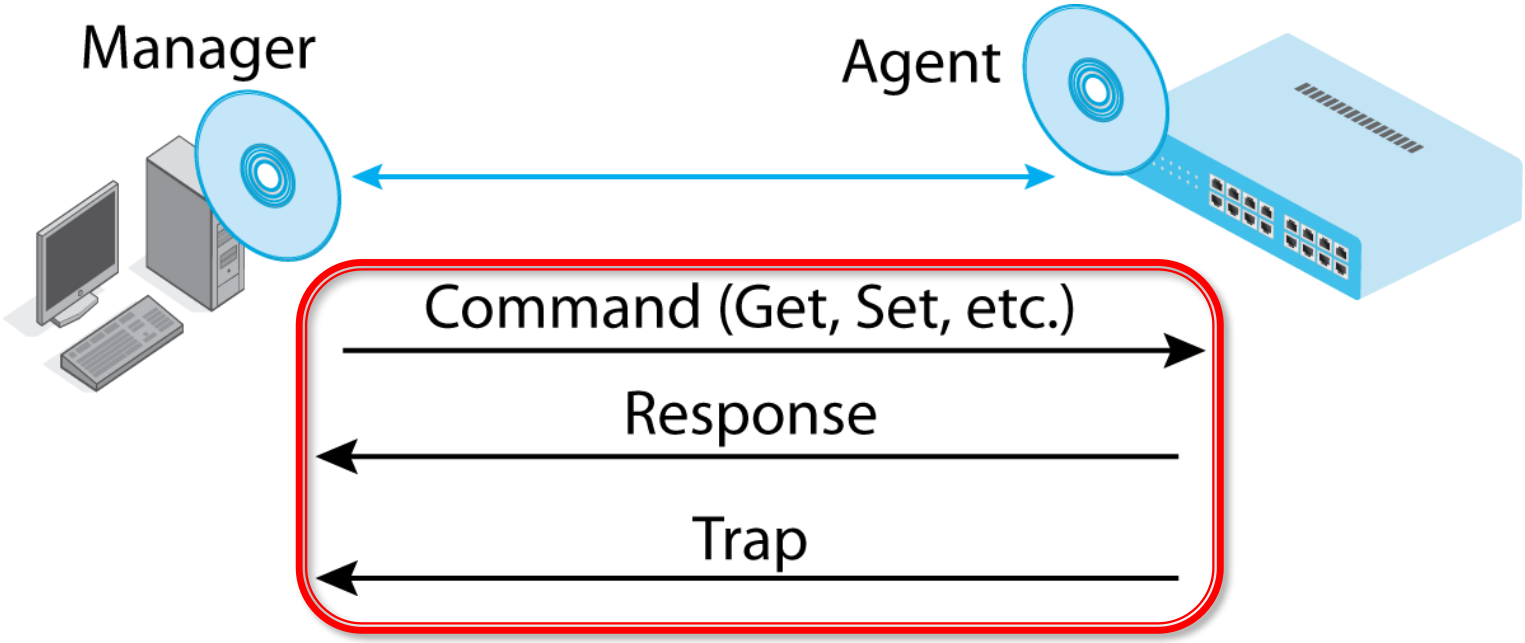
4.20: SNMP

- **Central manager** program communicates with each managed device.
- The manager communicates with a network management **agent on each device**.



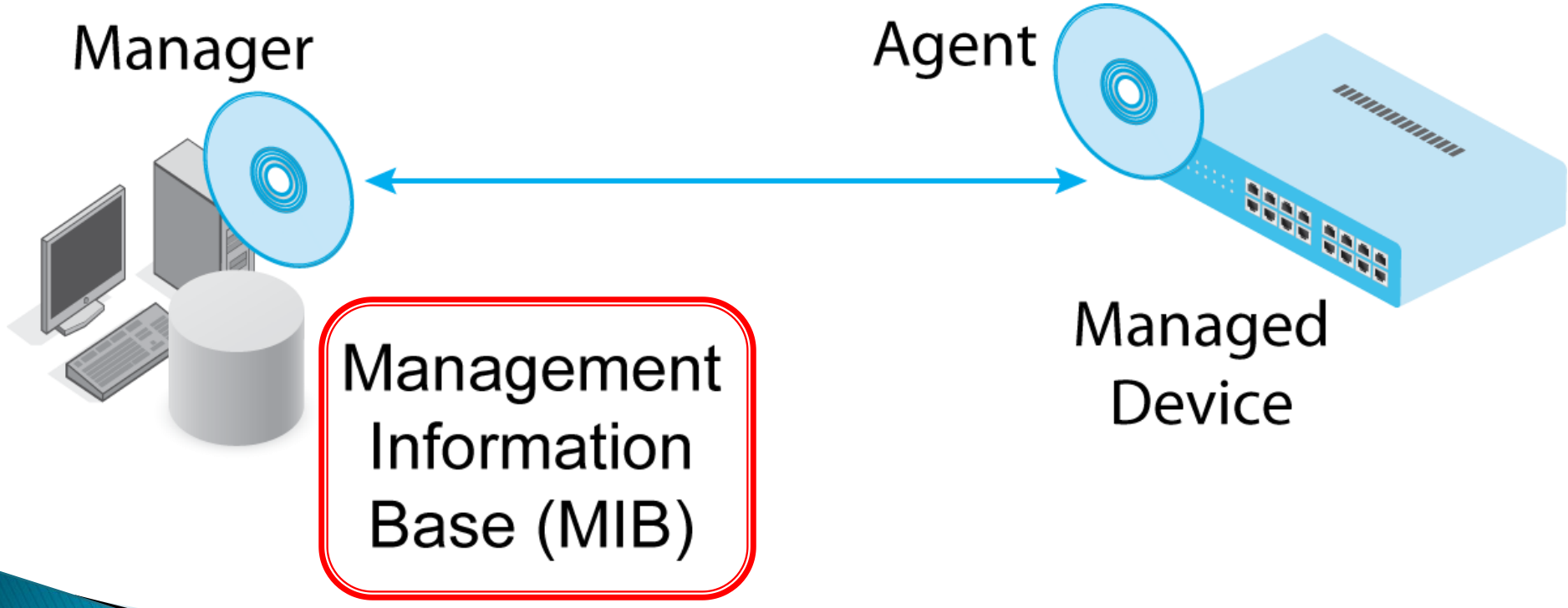
4.20: SNMP

- The manager sends SNMP commands and gets SNMP responses.
- Agents can send SNMP traps (alarms) if there are problems.

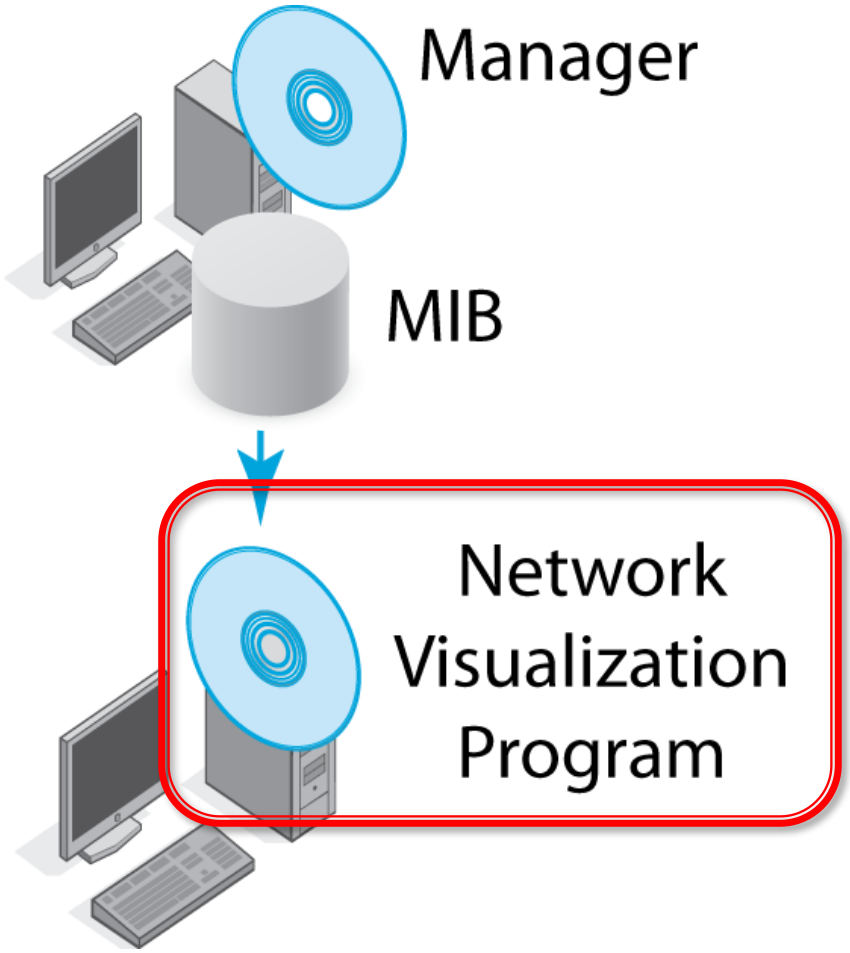


4.20: SNMP

- Information from agents is stored in the SNMP management information base.



SNMP

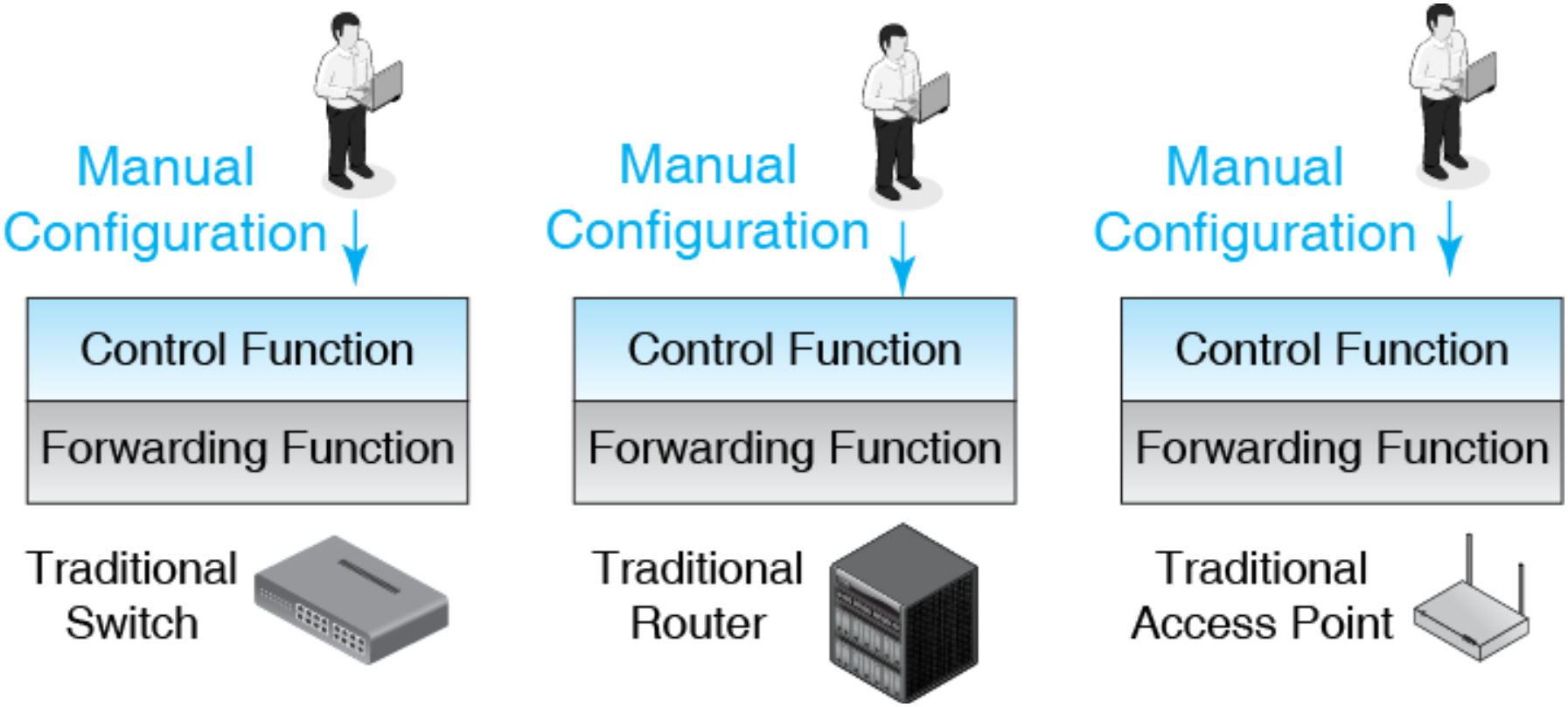


- Network visualization programs analyze information from the MIB to **portray** the network, do **troubleshooting**, and **answer** specific questions.
- SNMP **interactions are standardized**, but network **visualization program** functionality is **not**, in order not to constrain developers of visualization tools.

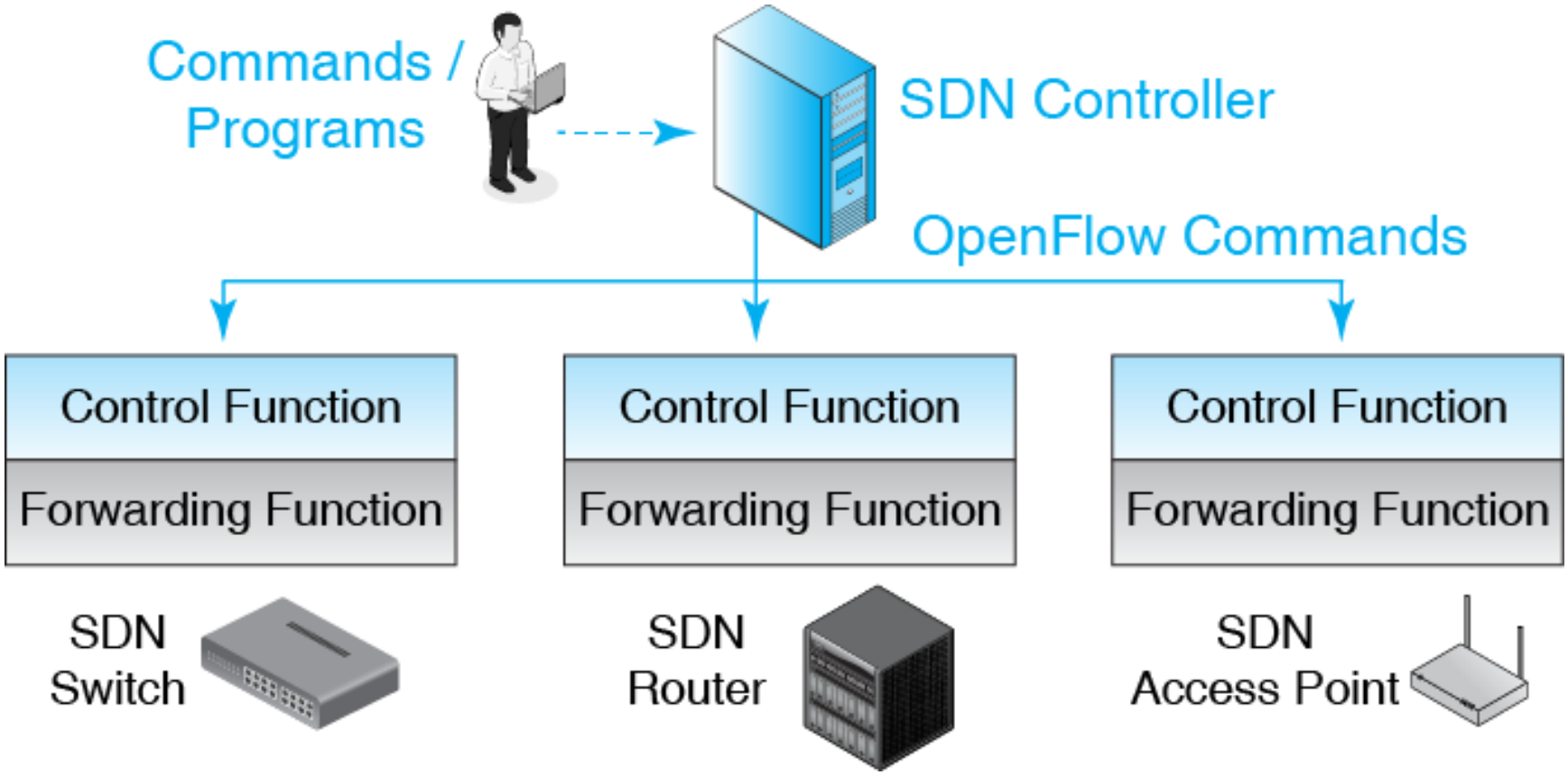
4.21 Traditional Device Control in Networking

- Firewall Forwarding
  - How the firewall deals with incoming packets
  - What interface (port) to send them out
- Firewall Control
  - Creates the rules for firewall forwarding
  - In comparison, firewall forwarding is comparatively simple

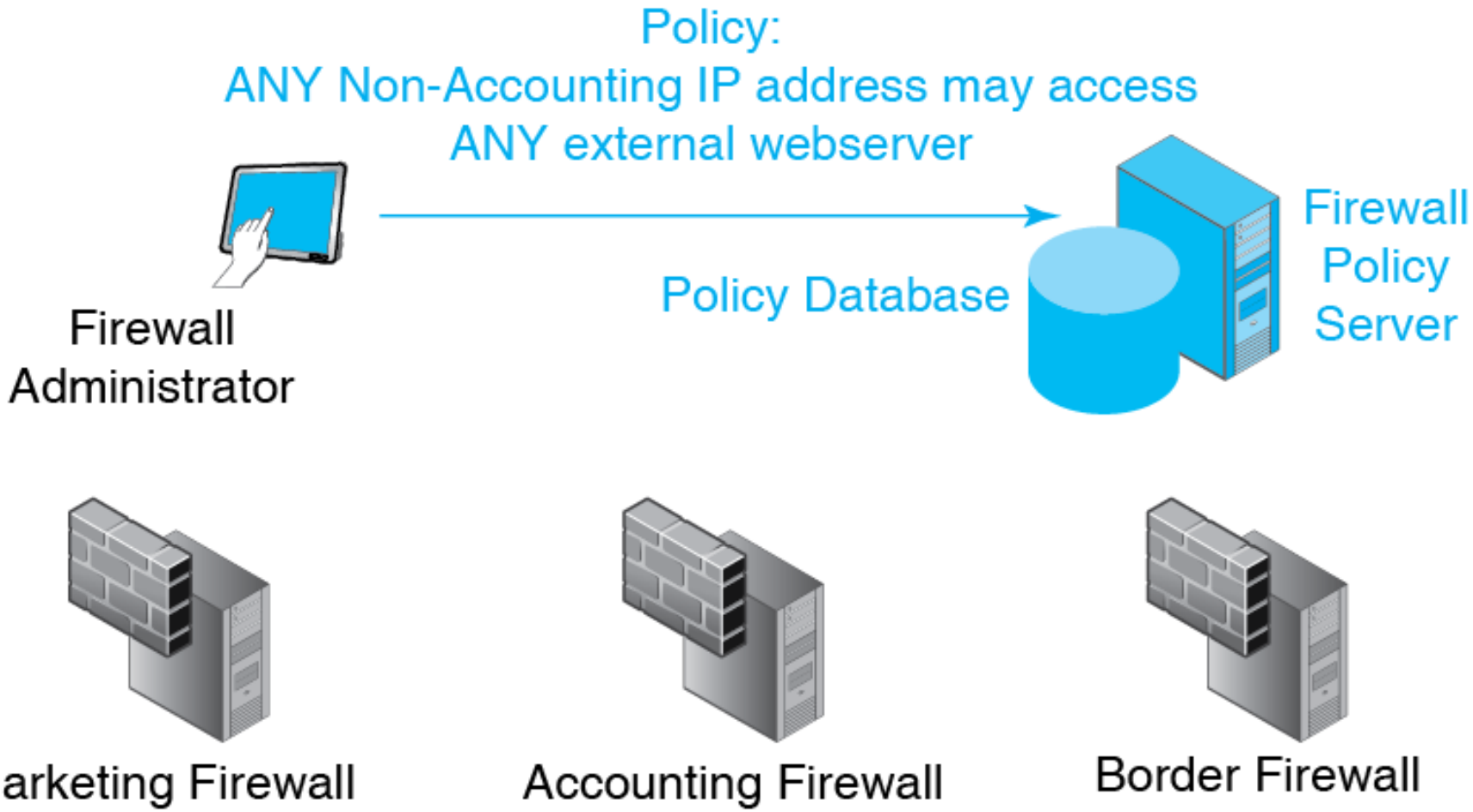
4.21 Traditional Device Control in Networking



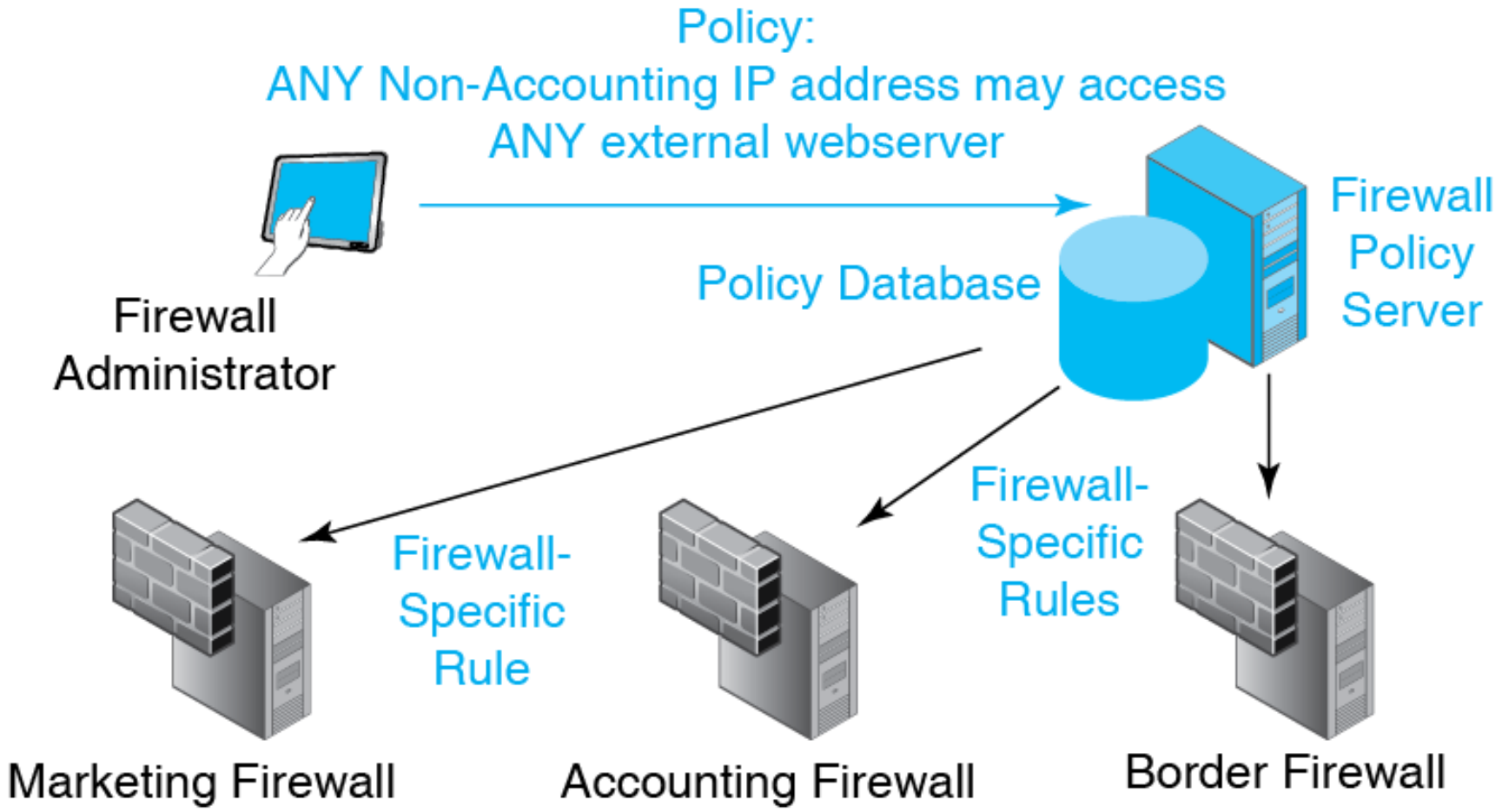
4.22 Software-Defined Networking (SDN) Control



4-23 Centralized Firewall Management



4-23 Centralized Firewall Management



Summary of Chapter 4

- Failure in the Target Breach
- Cost Matters
- Network Quality of Service QoS
- Network Design
- Security Planning Principles
- Centralized Management